DeepL
Subscribe to DeepL Pro to translate larger documents.
Visit www.DeepL.com/pro for more information.

INSA | LYON



Wireless Networks Architecture and Security

Walid Bechkit, INSA-Lyon, INRIA-CITI

citi lab

Inria
INVENTEURS DU MONDE NUMÉRIQUE

membre de
UNIVERSITÉ DE LYON

Overview of the training content

- **Introduction to security and wireless networks**
  - Basic concepts
  - Classifications and positioning
- **Wireless local area networks: WiFi 802.11**
  - Architecture and security
- **Network Access Control**
  - Principles, AAA, 801.1X, EAP, implementation
- **IoT technology security**
  - Architecture and security

Contributors

➢ Speaker and main contributor

– Walid Bechkit INSA-Lyon / INIRIA

walid.bechkit@{inria , insa-lyon}.fr

➢ Other contributors

– Matthieu Cunche, INSA-Lyon

– Francois Lesueur, INSA-Lyon

– Razvan Stanica, INSA-Lyon

– Yacine Challal, U.T.Compiègne

– Marine Minier, University of Lorraine

Objectives of this training

- Understand the different communication architectures and protocols through the study of different and representative types of networks;
- Learn about and understand the security solutions offered by wireless technologies (WiFi, Zigbee, LoraWAN, etc.);
- Become aware of the security issues raised by the proliferation of objects using wireless technologies;
- Know how to analyze the vulnerabilities of different technologies and attacks against wireless protocols;
- Know how to protect wireless communication environments against different attacks.

Introduction & Reminders

Basic security concepts

Security services

Verify the legitimacy of the access request

Make the information unintelligible to of other persons

Verify that the information has not been altered

Authentication

Confidentiality

Integrity





Alice





Bob

Other services

- **Non-repudiation**
  Ensuring that an action performed by an authenticated user cannot be repudiated by that user

- Availability (CIA)
  - An (industrial) system must remain accessible and operational
  - Otherwise, this will result in financial losses, delivery delays, etc.

- **Traceability**
  - Ability to retrieve the history of operations, use, location, etc. of an entity
  - Regulatory requirements in certain areas (nuclear, transportation, etc.)

- **Auditability**
  "Refers to the traceability of operations and controls performed and documentation produced; undocumented controls = not performed." *

* Methodological guide for IS auditability, ANSSI

Security services

Services de sécurité

Making information unintelligible to other people

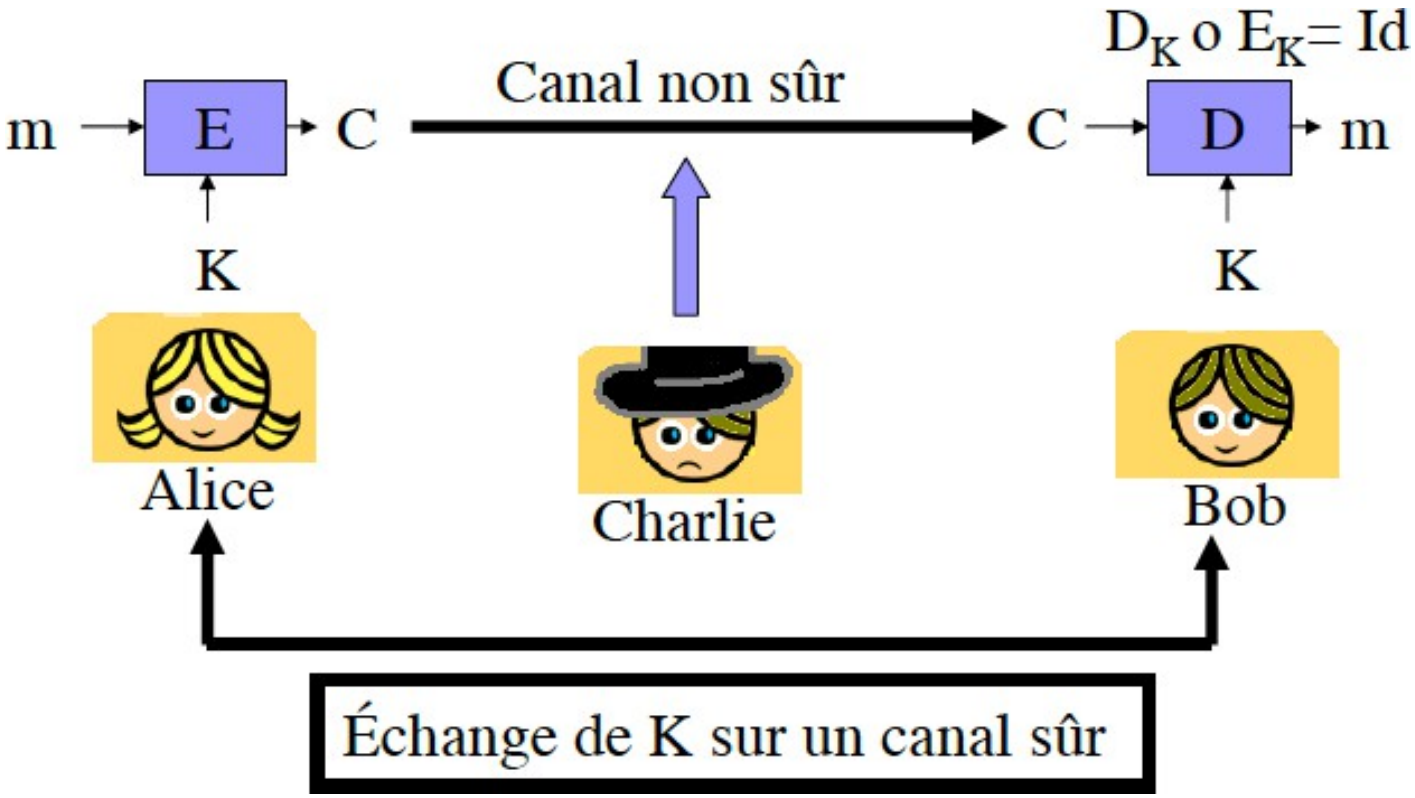
Confidentiality



Definitions:

Encryption / Decryption / Decryption / Cryptanalysis

Symmetric cryptography with private key



Same key for encryption and decryption

+ Very fast algorithms
+ Small key size

- Key distributions
- More keys to manage: n(n-1)

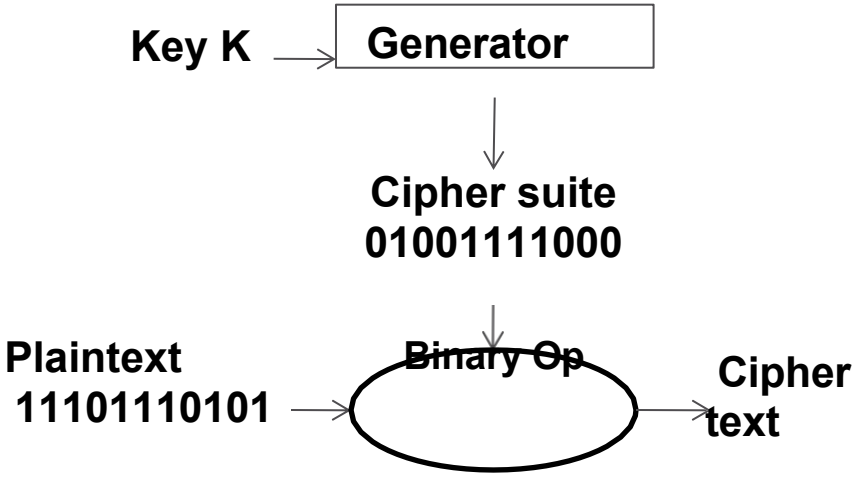
Symmetric encryption

Symmetric encryption by flow

+ Fast

- Vulnerable to cryptanalysis

Examples: **RC4**, **A5/1**, etc.

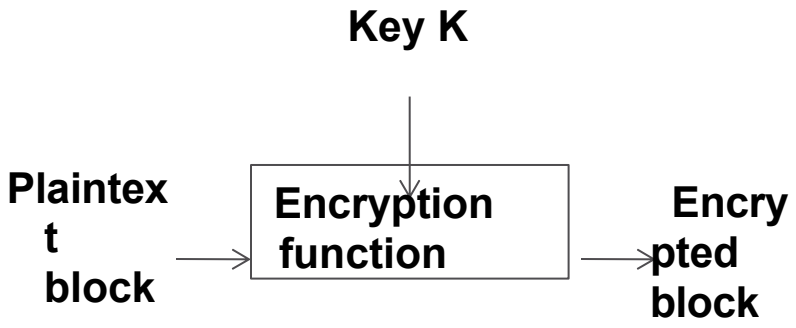


Symmetric block cipher

+ Less vulnerable to cryptanalysis

- Slow

- Examples: DES, **AES,** etc.



Example of AES symmetric encryption

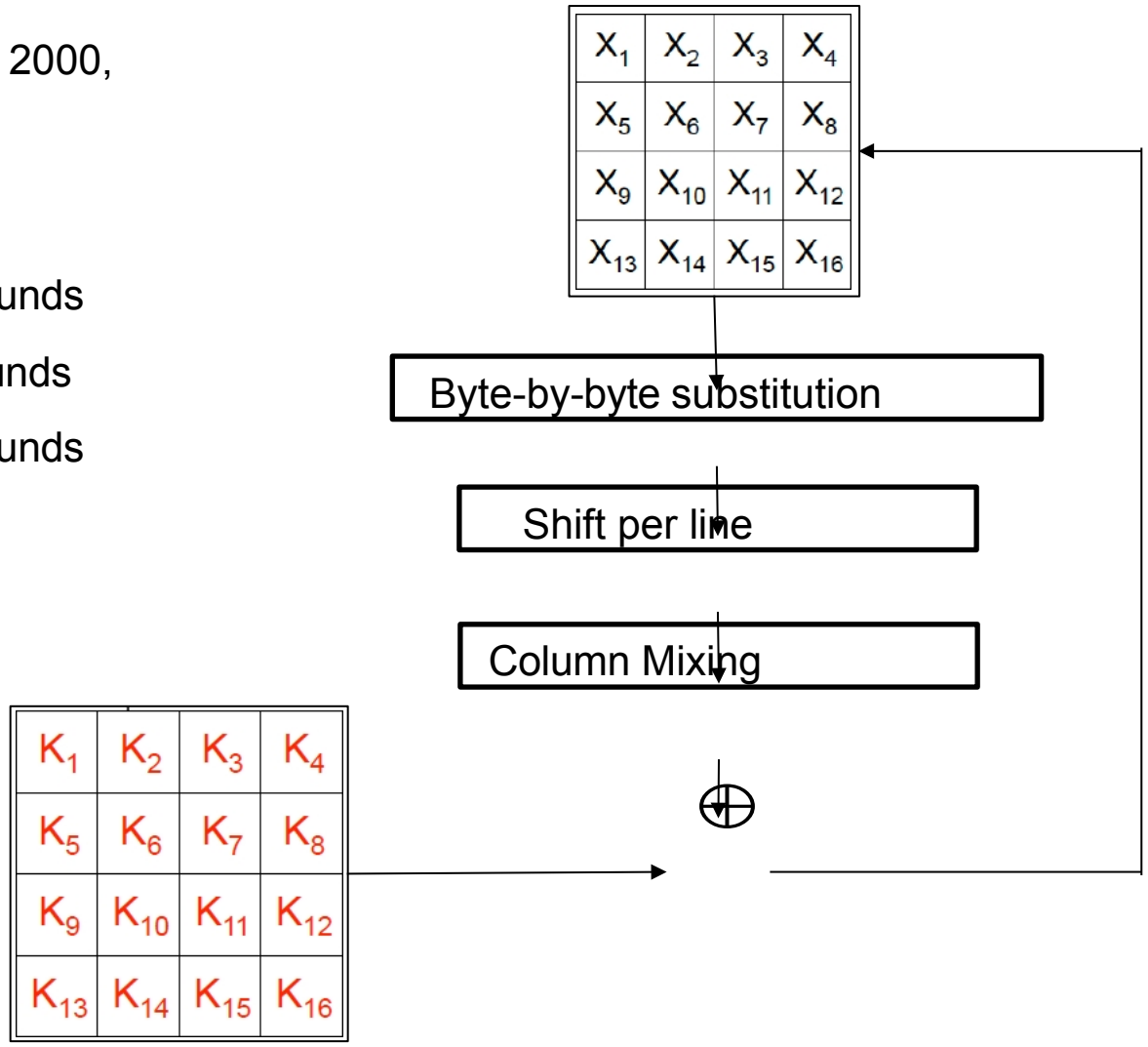
Won the AES competition in 2000,

launched in 1997 by NIST

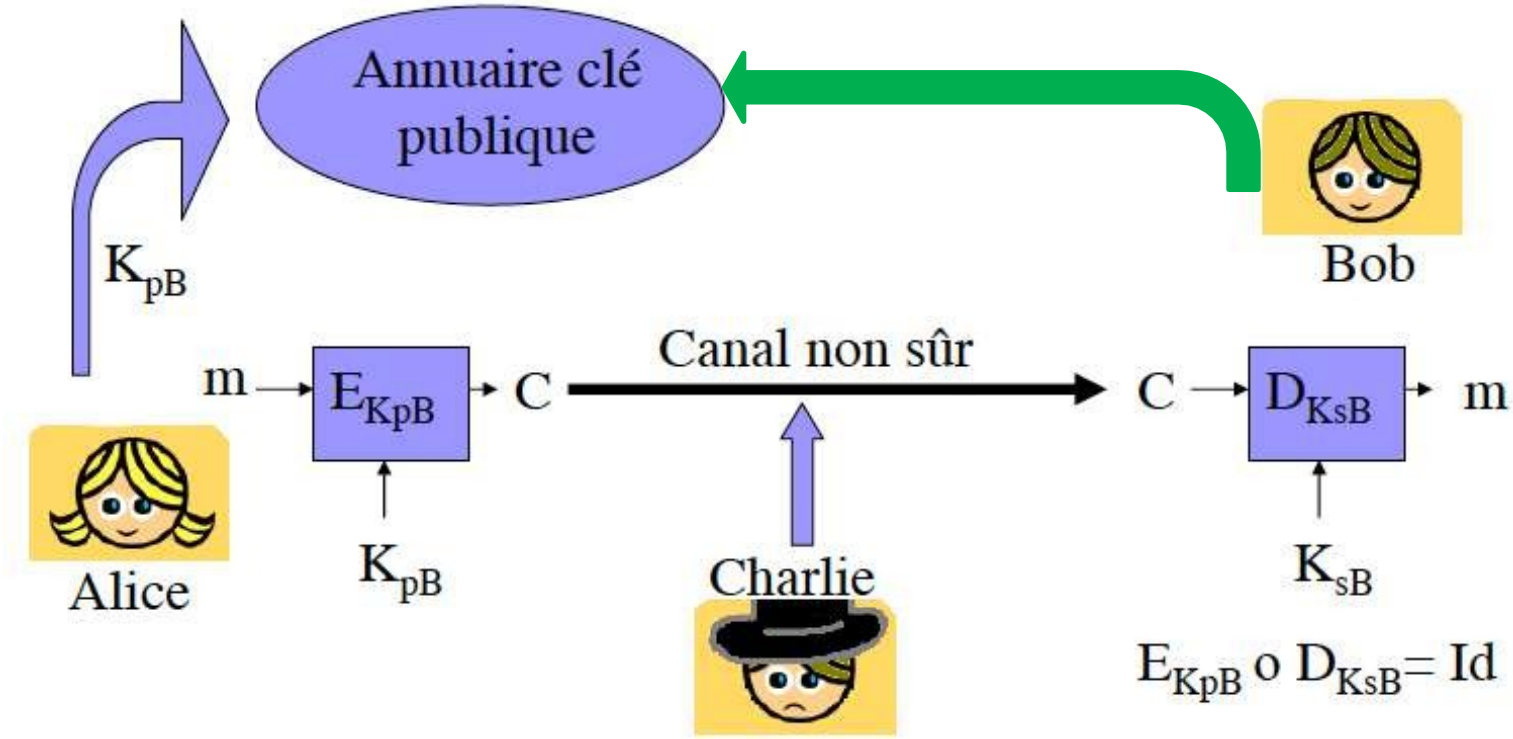
Key 128 bits --> 10 rounds

192 bits→ 12 rounds

256 bits --> 14 rounds



Asymmetric public key cryptography

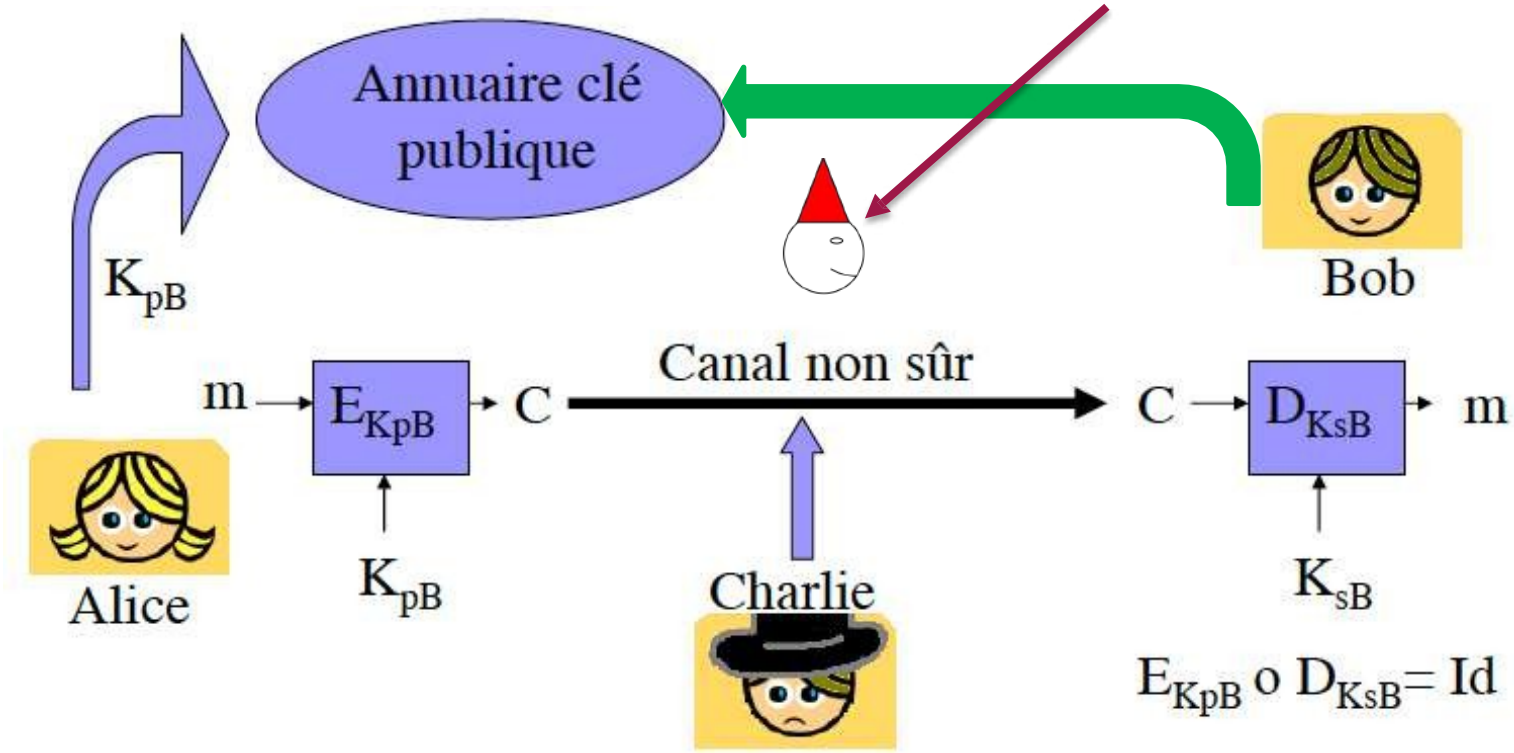


A public key and a private key

+ No key distribution problems
+ Fewer keys to manage 2.n

- Slow algorithms (~x1000)
- Key size

Asymmetric public key cryptography



- Public key authenticity issue→ PKI (CA, PGP, etc.)
- **Important: Public key for encryption and private key for decryption**

Example of RSA asymmetric encryption

- **Key generation:** Bob generates his keys
  - n=p.q with p and q two large prime numbers
    e.g.: p and q are 1024 bits (309 decimal digits each) Simple

    example for understanding: p=223 and q=233 n=51959
  - e prime with phi(n) = (p-1)(q-1) and d such that
    $e.d \equiv 1 \bmod (p-1)(q-1)$ In

    the example: e=5, d= 10301
  - Public key (n,e), private key d
    In the example: public key (5, 51959), private key 10301

Example of RSA asymmetric encryption

- **Encryption:** Alice wants to send a message m to Bob:
  - Alice calculates $C = M^e \bmod n$
  - Alice sends C to Bob

    In the example $C = M^5 \bmod 51959$

- **Decryption:** Bob decrypts c by calculating:
  - $C^d = (M^e)^d \bmod n$

    Using the example $M = C^{10301} \bmod 51959$

- → PKI asymmetric key management (CA, DNSSEC, PGP, etc.)

Symmetric encryption Symmetric encryption Asymmetric encryption:

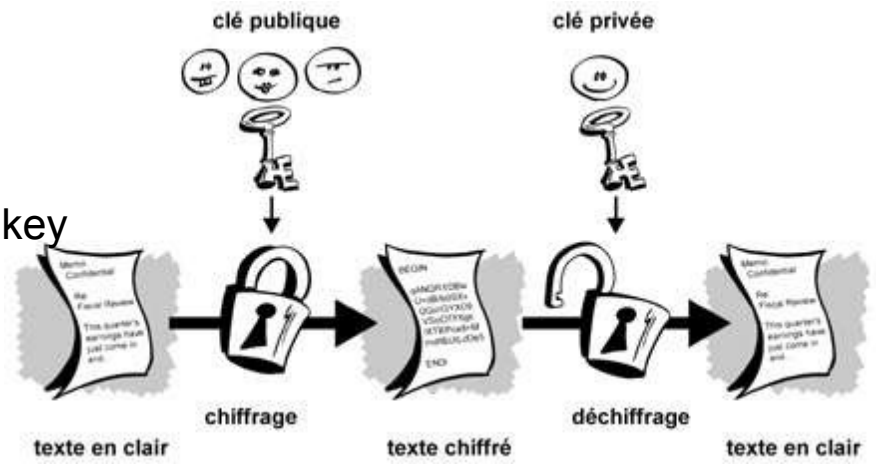
Chiffrement asymétrique:

Asymmetric encryption:

One public key for encryption and one private key for decryption (e.g., RSA)

+ No key distribution issues

- Slow (~ x1000)



Chiffrement symétrique:

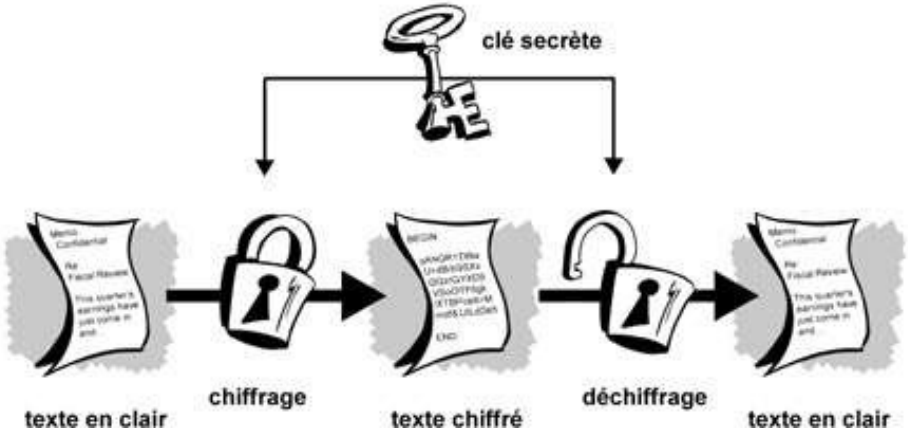
Symmetric encryption:

Same key for encryption and decryption

Example: AES

+ Fast

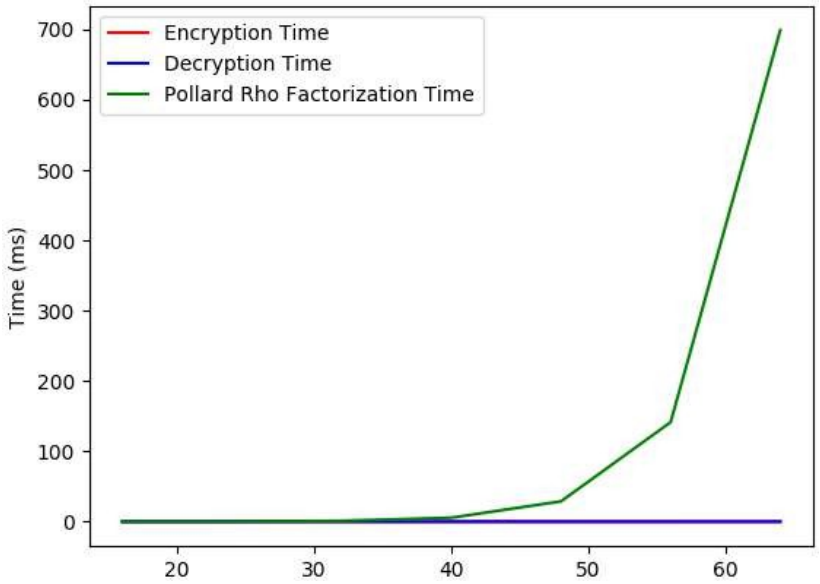
- Key distribution



Key size

Key size:

- Cryptanalysis for secret key systems is based on exhaustive search
- Cryptanalysis for public key systems is based on various complex problems (factorization of large numbers for RSA, discrete logarithms for elliptic curves, etc.).



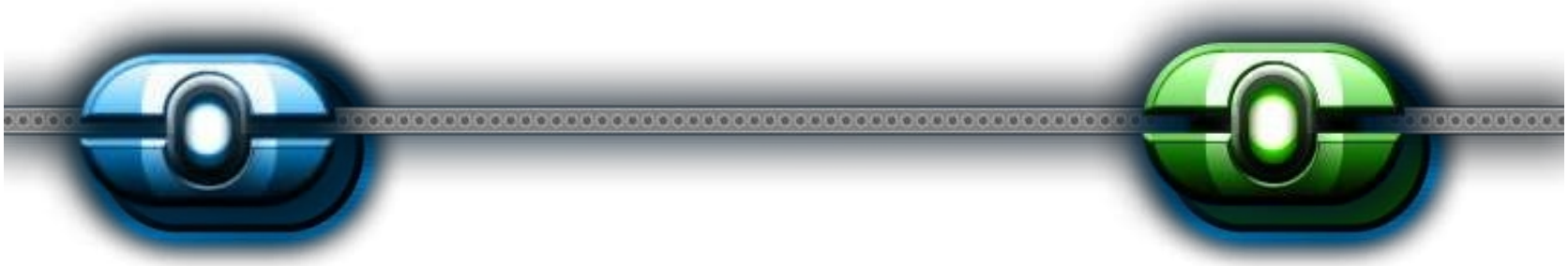
Security services

Verify that the information has not been altered

Verify the legitimacy of the access request

Authentication

Integrity



+ **Non-repudiation**: ensure that the sender of the message cannot deny having sent the message in the future.

Hash function

Fonction de hachage

- Calculate a digital fingerprint (hash), often small in size, to identify data
  - **One-way: it is** impossible to construct data from its hash.
  - The fingerprint is calculated "very quickly";
  - It is impossible to modify the data without modifying its hash
  - Impossible to find two different pieces of data with the same hash.
- Applications:
  - Password storage
  - Integrity (if the hash is exchanged over a secure channel!)
- Examples: MD-4, MD-5, SHA-1, SHA-256, etc.

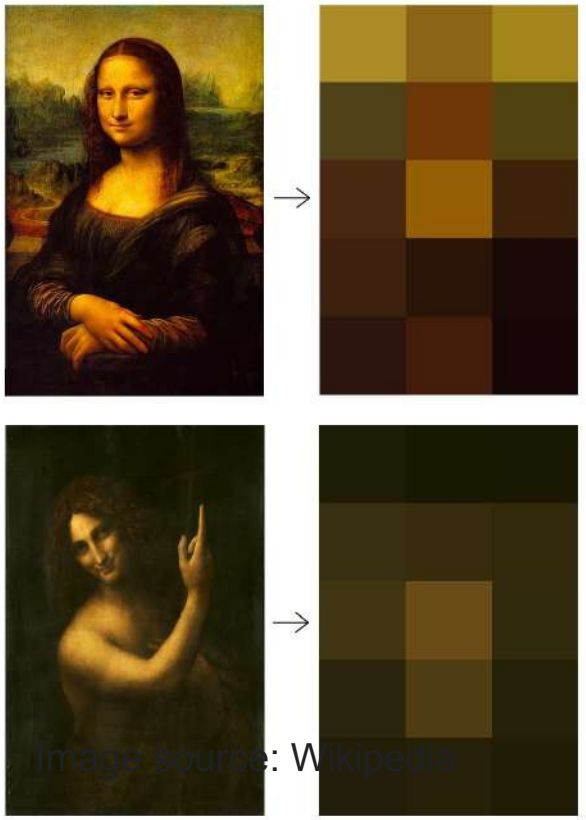


Image source: Wikipedia

Practical question: password storage

- Never store passwords in plain text
- Avoid storing encrypted passwords
- Why not store only the hash?→ rainbow tables
- Recommended solution:

  → **Salted hashes**

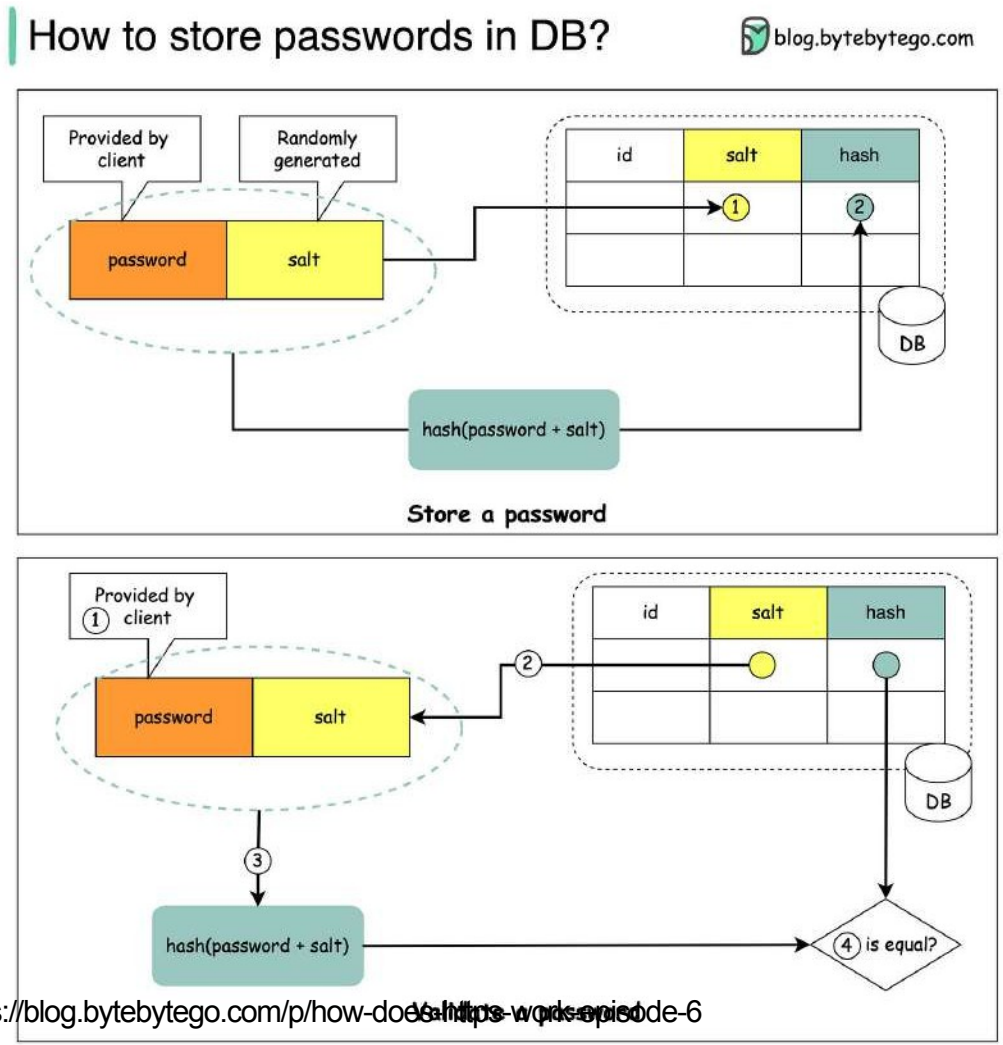


Image source: https://blog.bytebytego.com/p/how-does-https-work-episode-6

Digital signature

- Process that enables to ensure the the integrity of data and authenticate the author without them being able to deny having sent the data (non-repudiation)

- This **mechanism is based on asymmetric cryptography.**
- The signature is calculated using the issuer's private key
- The signature is verified using the issuer's public key

- Data can only be encrypted using the private key, but in practice, a hash of the data is encrypted.
- In practice, MD-5 + RSA, SHA256 + RSA, etc.

- Note: Signature→ **integrity, authentication, and non-repudiation**

Sealing

- Process that allows to ensure the the integrity of data and authenticate its author
- This **mechanism is based on symmetric cryptography**
- The result is called a seal, a MAC (message authentication code) or a MIC (message integrity code).

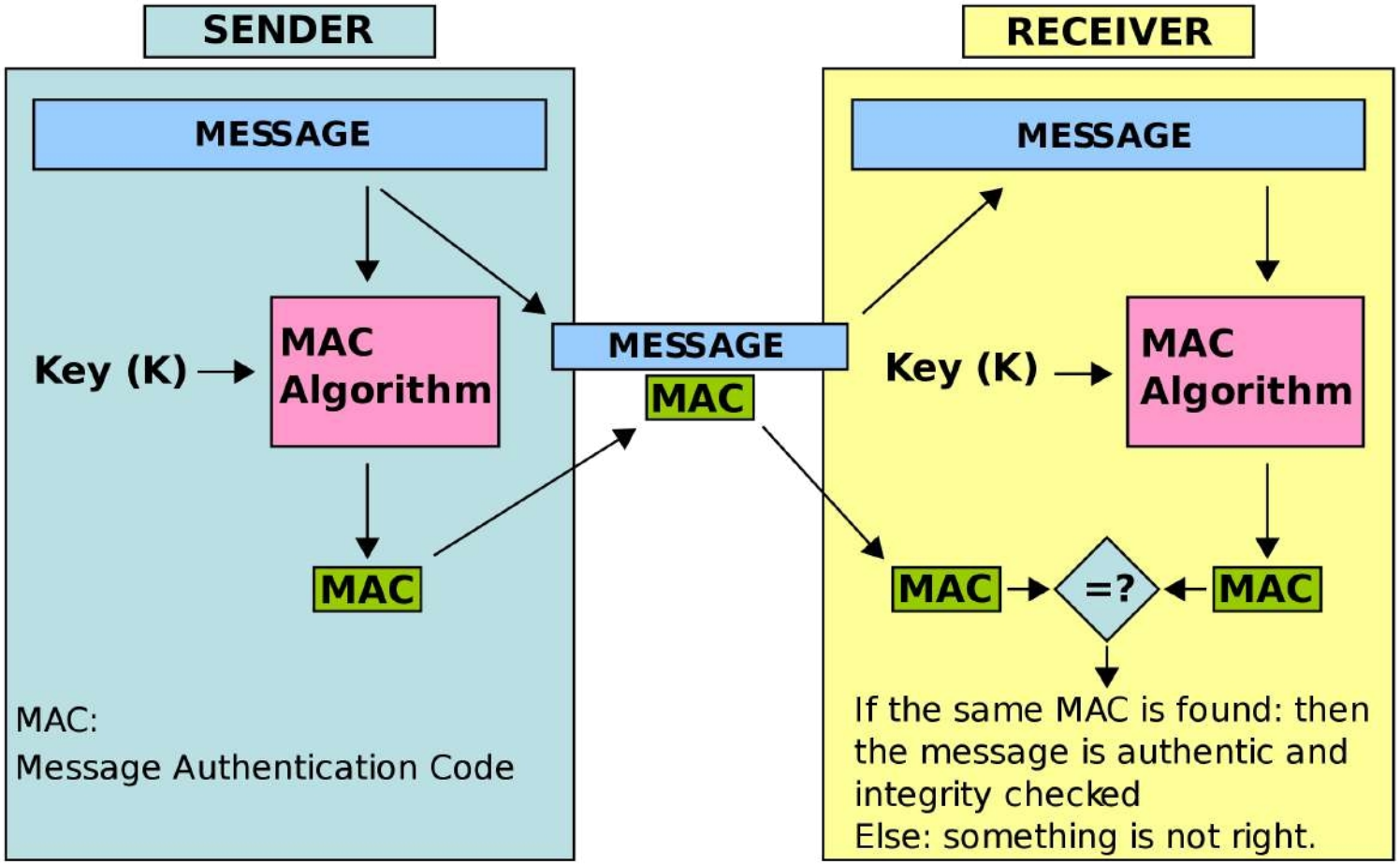
  Please note that in networking, MIC is preferred to avoid confusion!

- In practice, MIC is often calculated using:

  HMAC: combines the message with a secret key and applies a hash function (such as SHA-256) to produce an integrity code **CMAC**: splits the message into blocks, encrypts each block with a secret key, then combines the encrypted blocks to generate the integrity code

- Caution: Sealing→ integrity and authentication

Sealing



Source: Wikipedia

Key distribution problem

Symmetric/asymmetric key distribution

- **In symmetric cryptography**
  - Pre-distribution
  - Secure channel for key exchange (often using asymmetric cryptography)

- **In asymmetric cryptography**
  - By design, only public keys are exchanged
  - By design, it is **practically** "impossible" to deduce the private key from the public key within a reasonable amount of time
  - Public key authenticity problem!
  - MitM attack: Replace the exchanged public keys with your own keys
  - How can you be sure that the public key belongs to the entity you want to communicate with?
  - Solution→ **Public Key Infrastructure (PKI)**

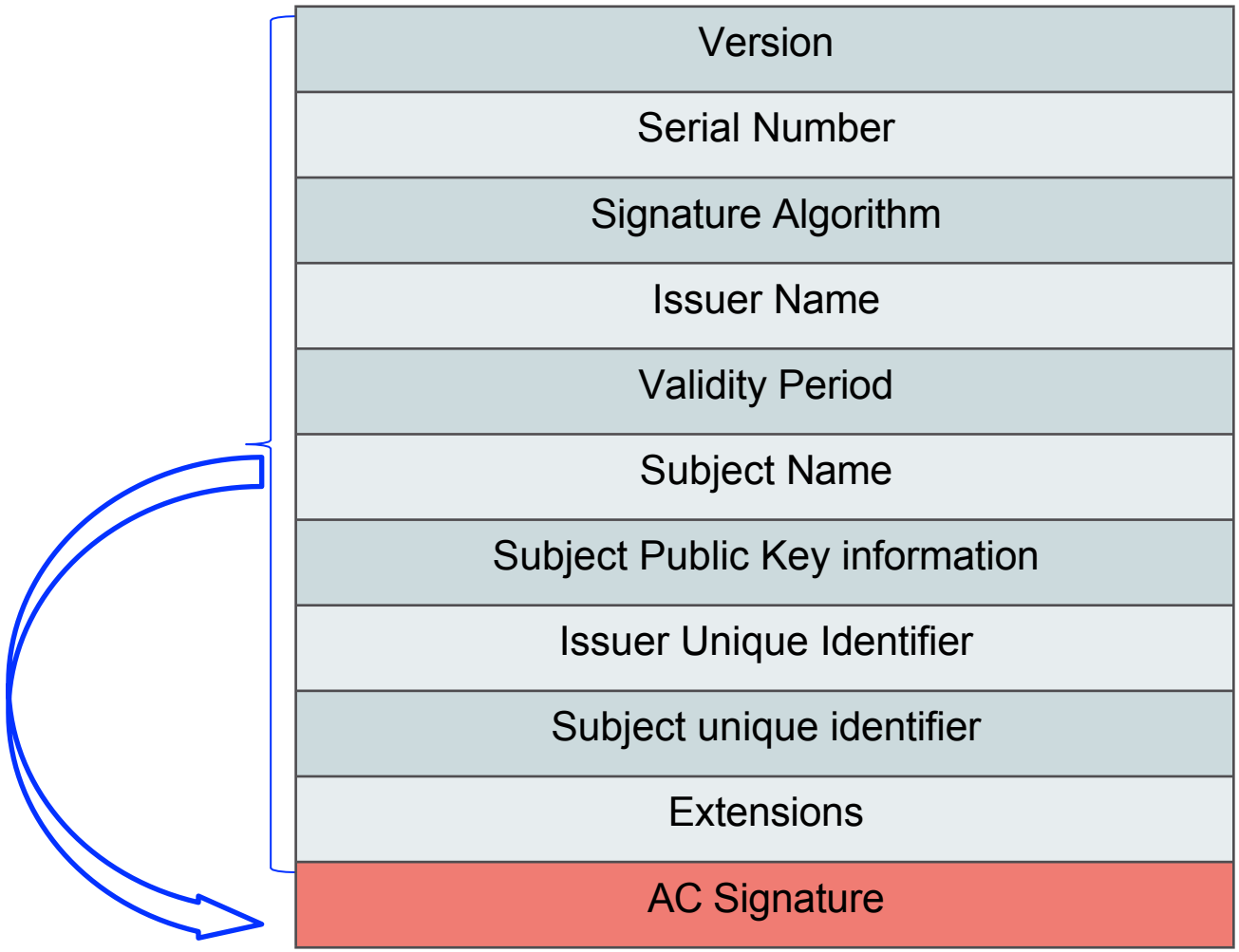
Public Key Infrastructure (PKI)

- Certification authorities
  - Trusted third parties
  - The basis of Transport Layer Security (TLS)
  - Also used for advanced electronic signatures
  - Most common certificate format: X.509 (RFC 52805)

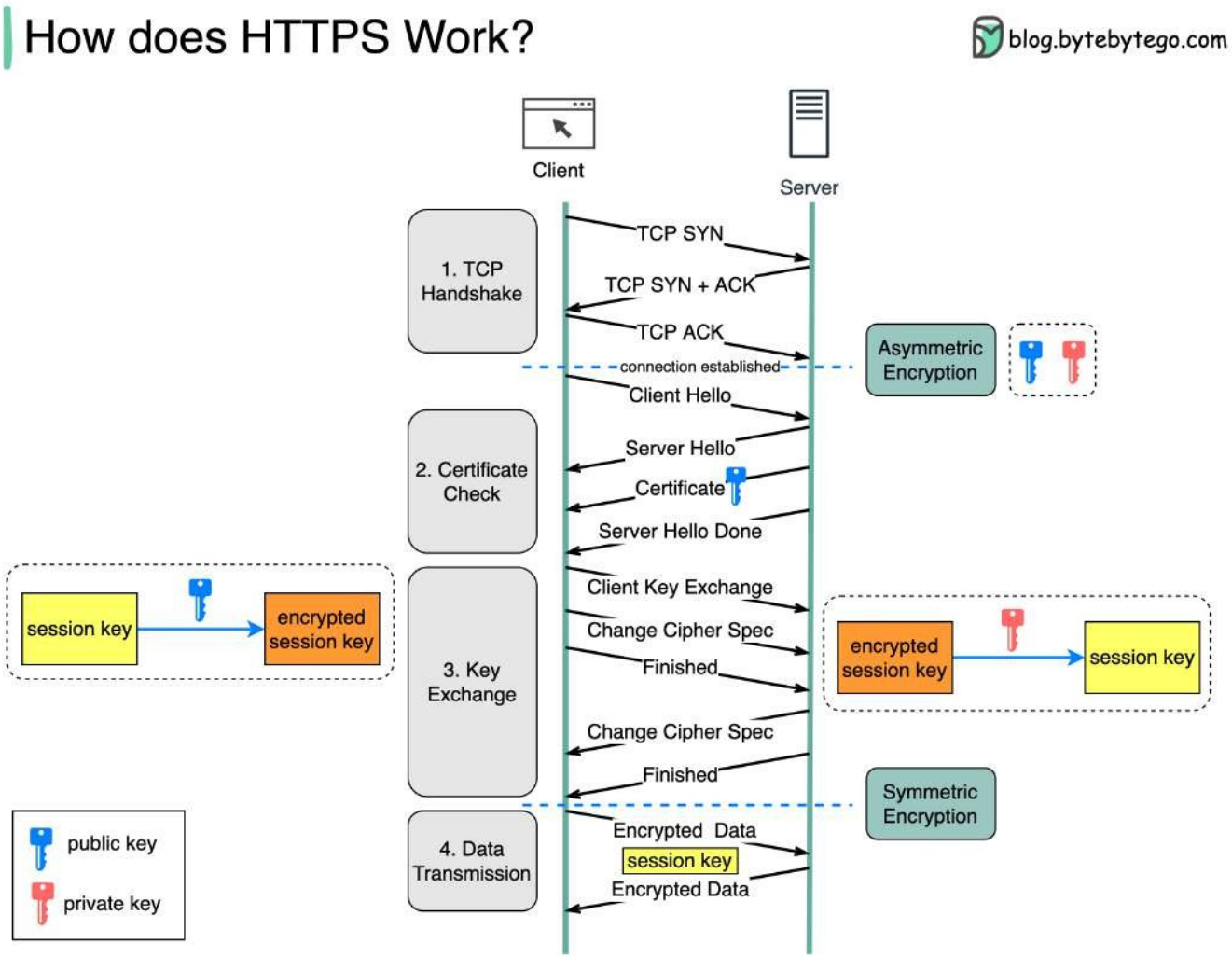
- The most common solution for HTTPs, SMTP, Secure Modbus, etc.

- Other solutions:
  - The web of trust (PGP)
  - DANE/DNSSEC
  - Blockchain-based solutions

X.509 certificate



HTTPs/TLS example



Source: https://blog.bytebytego.com/p/how-does-https-work-episode-6

Introduction & Reminders

Wireless Networks

Classification of wireless networks

Classification based on infrastructure

- **Networks with infrastructure** Base station, access point, etc. Generally single-hop networks Examples: cellular networks, Wi-Fi
- **Ad hoc networks**

  No infrastructure Coordination and self-organization

  Generally multi-hop networks

  Example: Wi-Fi Direct, sensor networks, etc.

Classification of wireless networks

Classification based on mobility

- **Static (fixed) networks:**

  Why wireless? Cost, accessibility of deployment areas, flexibility, etc.

  Example: Static sensor networks

- **Mobile networks**

  Some of the nodes are mobile

  No more scientific and technical barriers

  Ex: Cellular networks, vehicle networks, robot fleets, etc.

Classification of wireless networks

Classification based on radio range

- **Body Area Networks**

  Body sensor network

- **Personal Area Networks**

  Smart Home (Bluetooth, Zigbee, etc.)

- **Local Area Networks**

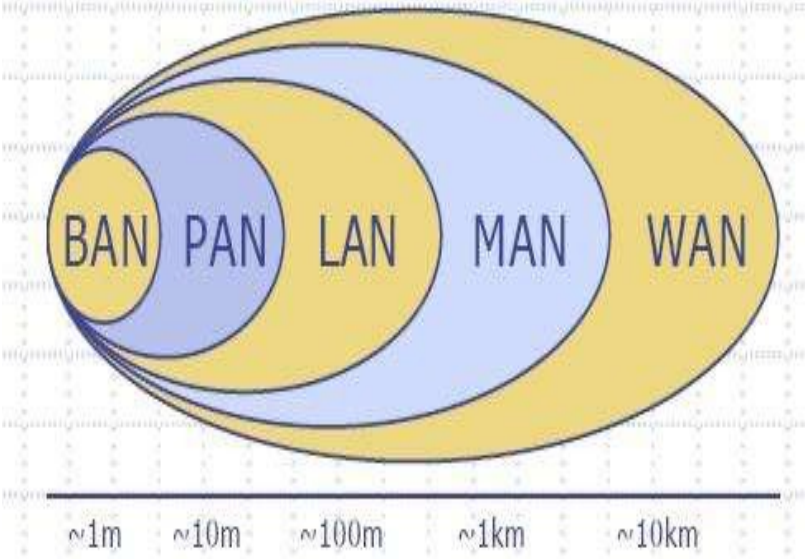
  Wireless LANs (802.11, etc.)

- **Metropolitan Area Networks**

  Metropolitan Networks (802.16, etc.)

- **Wide Area Networks**

  Cellular networks (2G, 3G, 4G, 5G, etc.) LP WAN (LoRa, SigFox, etc.)



Positioning and objective

Three types of wireless networks with different characteristics:

- ❑ **Wireless local area networks**
- ❑ ~~**Cellular networks**~~
- ❑ **Wireless sensor networks (IoT)**

Overall objective:

- ➢ Understand the architecture and challenges of wireless networks
- ➢ Understand the challenges of wireless communications security, some solutions, their limitations, and some research work

Detailed plan

- **Wireless local area networks: Wi-Fi**
  - General information and architecture
    - Infrastructure mode vs. ad hoc mode
    - WiFi channels
    - Channel access policy in 802.11
  - WiFi network security
    - Need for WiFi security
    - WEP protocol: Principle, limitations, and attacks
    - WPA/WPA2/WPA3 protocols: principle and attacks

Detailed plan

- **Network Access Control**
  - Principles, AAA, 802.1X, EAP, implementation

- **Wireless Sensor Networks (IoT)**
  - Introduction to wireless sensor networks
  - Communication in WSNs
  - Energy saving in WSNs

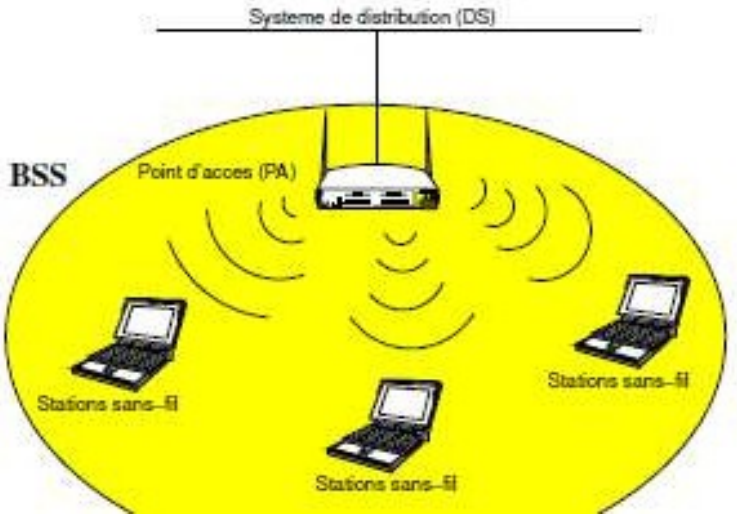
  - Basic principles of security in sensor networks
  - Contributions to the security of wireless sensor networks

Wireless local area networks (Wi-Fi)

Architecture and communication

802.11 modes: infrastructure mode

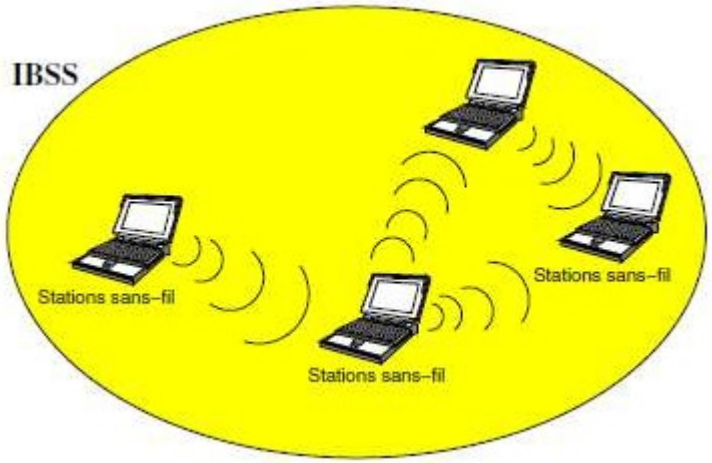
- Special station called Access Point (AP)
- Two Wi-Fi stations connect to each other via their shared AP
- A station connects to the network via the AP.
- Stations within radio range of the AP form a BSS (Basic Service Set).
- Each BSS is identified by a **BSSID**
  (MAC address of the AP)



802.11 modes: Ad-Hoc mode

- Fully distributed operation without infrastructure
- No elements structuring the cell hierarchically
- Each station also acts as a router
- Stations within radio range form an **IBSS** (Independent Basic Service Set)
- One station acts as a virtual AP
- IBSS ID: @ MAC of the virtual AP

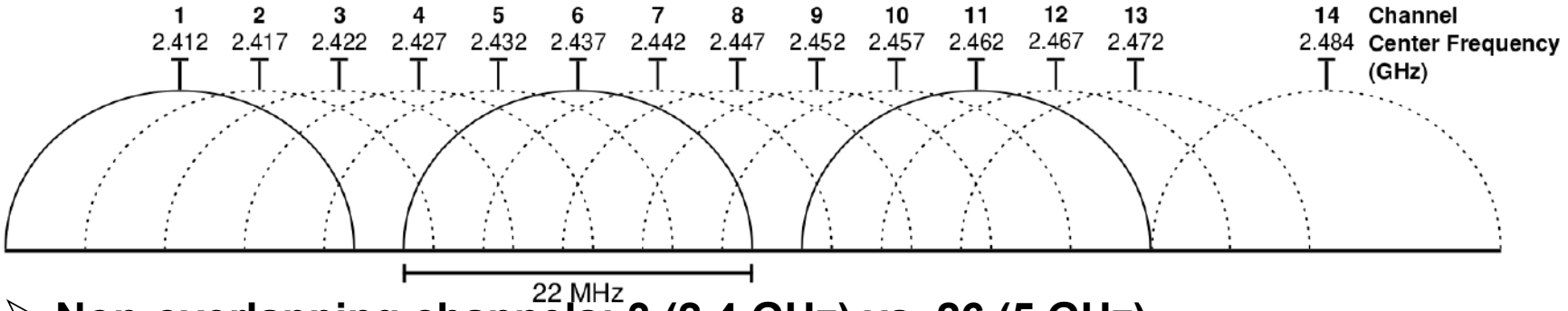
- Used for field networks



Physical layer: 802.11 channels

- **2.4 and 5 GHz ISM band:**
  - 2.4 GHz band: 2.4 to 2.5 GHz (2.400 to 2.483 in Europe)
  - 5 GHz band: 5.725-5.875 GHz
  - Division into 20 or 22 MHz channels

- **Example: List of 802.11 channels (2.4 GHz)**



- **Non-overlapping channels: 3 (2.4 GHz) vs. 26 (5 GHz)**

802.11 standards

Standard	Release date	Frequency (GHz)	Bandwidth band (MHz)	Maximum data rate (Mbit/s)	Modulation
802.11	1997	2.4	22	**2**	DSSS, FHSS
802.11a	1999	5	20	**54**	OFDM
		3.7			
802.11b	1999	2.4	22	**11**	DSSS
802.11g	2003	2.4	20	**54**	OFDM
802.11n	2009	2.4/5	20	**65**	MIMO-OFDM
			40	**135**	
802.11ac	2014	5	20	**86.7**	
			40	**180**	
			80	**390**	
			160	**780**	
802.11ax	2020	2.4/5		**10,000**	MIMO-OFDMA

MAC 802.11 DCF: CSMA/CA

- Listen to the channel (Carrier Sense) during DIFS. If it is free, transmit and wait for an explicit acknowledgment; otherwise, wait until it is free + DIFS.
- If the timeout is reached, go to the **Backoff Procedure**
- **Backoff Procedure in 802.11:**
  - Initialize a timer with a random value between 0 and W_max (initially equal to 7);
  - Decrement the timer as long as the medium is free (if the medium is busy, the countdown is blocked)
- When the value is zero, transmit and wait for an explicit acknowledgment
- If the timeout is reached, go to the **Backoff Procedure**, doubling the maximum value of the timer (W_max=W_max*2)

MAC 802.11 PCF: Point Coordination Function

- Supported in Infrastructure mode only
- Priority over DCF but rarely implemented
- The AP periodically sends beacon frames: divide the channel into CFP (contention-free period) and PC (contention period)
- During the CFP, the access point queries the stations in turn
- Designed for the transmission of sensitive data (real-time applications: voice, video, etc.)
- Access guaranteed but lower performance

Error control (CRC)

- Based on polynomial division calculations with coefficients in {0,1}
- Use of **generator polynomials** with specific mathematical properties:
  - CRC-12 = $x^{12} + x^{11} + x^3 + x^2 + x + 1$
  - CRC-16 = $x^{16} + x^{15} + x^2 + 1$
  - CRC-32 = $x^{32} + x^{26} + x^{23} + x^{22} + x^{16} + x^{12} + x^{11} + x^{10} + x^8 + x^7 + x^5 + x^4 + x + 1$
- Examples: Ethernet: CRC-32, ZIP CRC-16 or 32
- Calculation of CRC during transmission:
  - Add m zeros to the binary word to be transmitted (m: degree of the generator polynomial)
  - Perform a Euclidean division of the resulting word by the generator polynomial
  - The remainder of the division corresponds to the CRC to be added to the word before transmission

* Claude Duvallet, error-correcting codes and detector codes, master's degree course in computer science

Error checking (CRC)

- Example: CRC-4, generator polynomial x4+X2+x (10110)
- Binary word to be transmitted: **1 1 1 1 0 1 1 1 0 1**

x^{13}	x^{12}	x^{11}	x^{10}		x^8	x^7	x^6		x^4			x^4	$+x^2$	$+x$
x^{13}		x^{11}	x^{10}											
	x^{12}				x^8	x^7	x^6		x^4			x^9	$+x^8$	$+x^6$
	x^{12}		x^{10}	x^9								$+x^5$	$+x^3$	$+x^2$
			x^{10}	x^9	x^8	x^7	x^6		x^4			$+x$		
			x^{10}		x^8	x^7								
				x^9			x^6		x^4					
				x^9		x^7	x^6							
						x^7			x^4					
						x^7		x^5	x^4					
								x^5						
								x^5		x^3	x^2			
										x^3	x^2			

- CRC = $x^{3}+x^{2}$ = 1100→ mit 1111011101 1100

* Claude Duvallet, error-correcting codes and detector codes, master's degree course in computer science

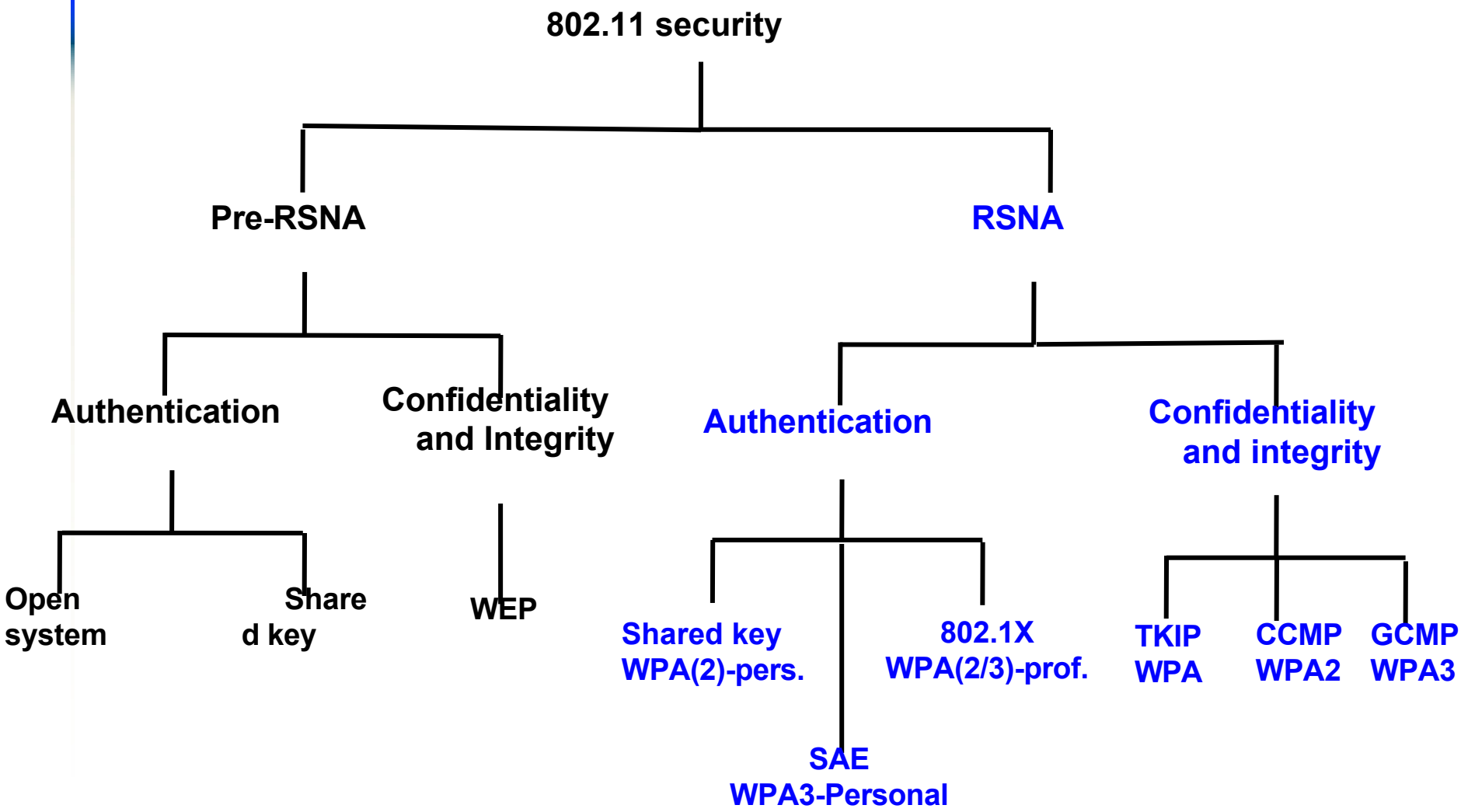
Wireless local area networks (Wi-Fi)

Security

Need for Wi-Fi security

- Wireless transmission –> transmissions can easily be intercepted by an undetectable analyzer
- Types of attacks
  - Eavesdropping
  - Modification of messages (content, IP address, etc.)
  - Packet injection
  - Denial of service (jamming, disassociations), etc.
- Encryption required (confidentiality)
- Authentication and integrity required

Wi-Fi security: Summary



Wired Equivalent Privacy (WEP)

- A secret key preloaded by the administrator
- Size: **40, 104**, **or 232 bits** (5.13 or 29 bytes)
- Examples:

  1A648C9FE2, 'XYZ12'

  99D767BAC38EA23B0C0176D152

- The same key for authentication and encryption
- Use of WEP is optional

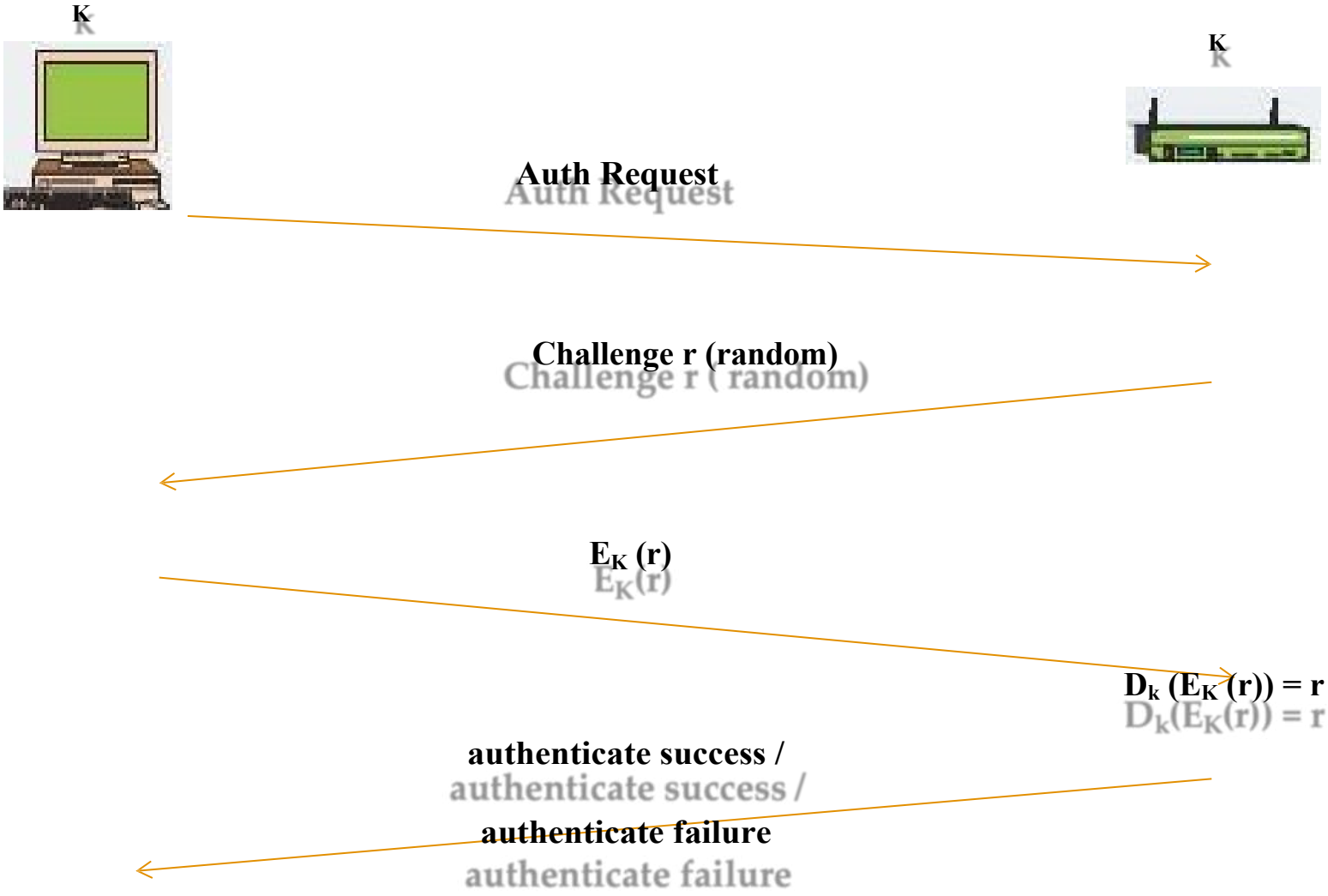
- Addition of a **24-bit (3-byte)** initialization vector (**IV)** to form a 64-, 128-, or 256-bit key

- Example (128 bits): IV = K[0] || K[1] || K[2], secret key = K[3] || … || K[15]

WEP authentication

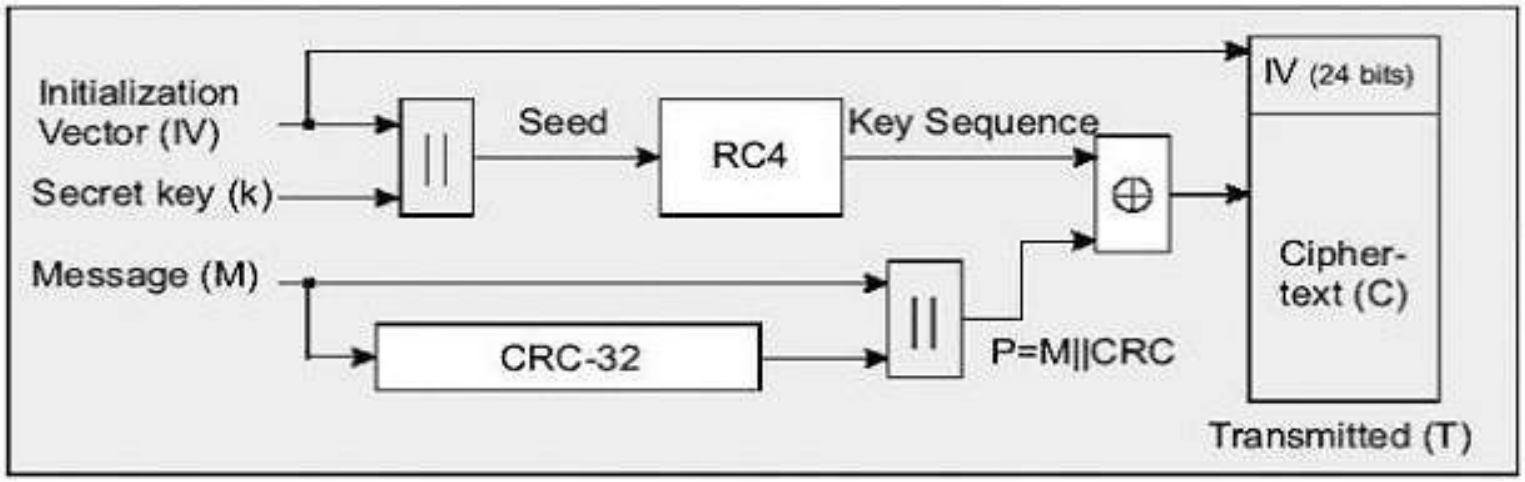
- Open System authentication:
  - The station sends its ID and the access point returns the authentication response;
- Pre-shared key (PSK) authentication:
  - The station sends an authentication request to the access point (AP);
  - The access point sends plain text (128 bytes) for a challenge;
  - The client station must encrypt the plain text using the WEP key and send it back to the AP;
  - The access point decrypts the text and compares it to the plain text sent, then sends a positive or negative response;
  - After authentication and association, WEP can be used to encrypt data.

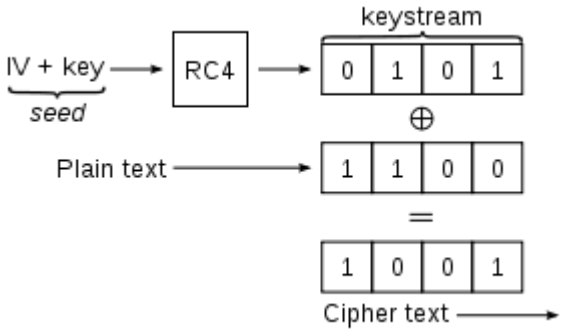
WEP authentication



Confidentiality and integrity WEP: RC4/CRC

- RC4 stream cipher algorithm (40, 104, or 232-bit key)





- CRC-32 checksum

WEP confidentiality and integrity:

- Why use a different IV per packet when it is transmitted in clear text?

...what if we used the same IV?

- More details below

WEP confidentiality: RC4 – just for your information

- **General principle:**

  Random number generation from a 256-byte state table S_i

- **Initialization of the array from key K**

  For i from 0 to 255, S_i = i

  For i from 0 to L: (K_i = byte i of key K) j = 0

  for i from 0 to 255

  j = (j + S_i + $K_{(i \bmod L)}$) mod 256 Swap S_i and S_j

- **Generation of the random number:**

  i = (i+1) mod 256, j = (j + S_j) mod 256

  Swap S_i and S_j

  t = (S_i + S_j) mod 256 => output S_t

WEP integrity:CRC

- Based on polynomial division calculations with coefficients in {0,1}
- **Ex (CRC-2):**

6 bits de données: 110101 , Polynôme générateur 101 : x^2+1

```
1 1 0 1 0 1 0 0 | 1 0 1
1 0 1           |-------
0 1 1 1         | 1 1 1 0 1 1
  1 0 1         |
  0 1 0 0       |
    1 0 1       |
    0 0 1 1 0   |
        1 0 1   |
        0 1 1 0 |
          1 0 1 |
Reste= 0 1 1    |
```

On envoie E= 110101 11

- Examples: Ethernet, WEP (CRC-32), ZIP (CRC-16 or 32)

WEP vulnerabilities

A- False authentication based on valid authentication

B- Replay attack

C- Modification/injection of packets

D- Ease of finding the encryption suite →

- ❑ Possibility of "decrypting" packets (without possessing the key)
- ❑ Possibility of injecting packets
- ❑ Performing false authentications

E- Ability to recover the initial key "quickly"

WEP vulnerabilities: Why?

- Very simple authentication scheme
- Symmetric stream cipher
- Small IV vector size
- Use of CRC as a mechanism to ensure integrity (linearity of CRC)
- No anti-replay mechanism
- Use of the initial key as the session key (no temporary keys)

Attacks against WEP(A): false authentication

- **Challenge-response approach:**

  STA –> AP: authenticate request

  AP –> STA: 128-byte authenticate challenge (c)

  STA –> AP: authenticate response IV,E(c) = c ⊕ RC4(IV || K) AP –> STA: authenticate success or failure

  …

  The attacker can calculate c ⊕ (c ⊕ KS) = KS AP→

  attacker: c'

  attacker→ AP: IV | c' ⊕ c ⊕ (c ⊕ KS) = c' ⊕ KS

- **Authentication is one-way:**
  - AP does not authenticate with STA
  - STA risks associating with a malicious AP

Attacks against WEP (B/C): replay and modification

- **Replay attack:**
  - WEP does not provide recommendations on the choice of IV
  - IV is transmitted in clear text

    → possibility of replaying old messages

- **Packet modification (CRC linearity):**

$$CRC(X \oplus Y) = CRC(X) \oplus CRC(Y)$$

- The attacker listens to $E(M)=(M \mid CRC(M)) \oplus KS$, where KS is the output of RC4
- For each ΔM, the attacker can calculate $CRC(\Delta M)$ and thus: $((M \mid CRC(M)) \oplus KS) \oplus (\Delta M \mid CRC(\Delta M)) =$

$$((M \oplus \Delta M) \mid (CRC(M) \oplus CRC(\Delta M))) \oplus KS =$$

$$((M \oplus \Delta M) \mid CRC(M \oplus \Delta M)) \oplus KS$$

Attacks against WEP (D): finding the encryption suite

- **Consequences:**
  - Ability to "decrypt" packets using compromised IVs. E.g.: throughput of 11Mbps + average size of 1500 bytes→ 1 collision every 5 hours
  - Inject valid packets into the network.
  - Perform fake authentications

- **Attack 1: Exploit the reuse of initialization vectors**
  - The IV size is very small (24 bits)
  - For a 24-bit initialization vector + unique key→ 16,777,216 possible pairs (IV, key stream)
  - By knowing the plaintext of a message M (ARP request, DHCP, etc.) and its ciphertext (IV, Enc(M)), the associated key stream can be deduced

Attacks against WEP (D): finding the encryption suite

- **Attack 2: Inductive attack (KoreK chopchop attack):**
  - Recovery of the first n bytes of the cipher suite (messages from known ARP and DHCP protocols)
  - Discover the entire encryption suite (by calculating the CRC32 error code), repeating for each byte:
    1- Generate a message of size n-3 bytes resulting in a predictable response
    2- Calculate the CRC (4 bytes) of this message and consider the first 3 bytes.
    3- Transmit the encrypted message obtained (n-3 + 3 bytes) concatenated with an additional byte constructed by exhaustive search (255 values).
    4- XOR between the 4th byte of the CRC and the (n+ 1) valid byte
  - There is a variant based on a reverse deduction (variant implemented in aircrack-ng)

Attacks against WEP (E): finding the key

- **Brute force attack:**
  - Try all possible combinations
  - 64/40-bit keys→ About ten hours with a simple computer
- **Dictionary attack:**
  - More suitable for 128- and 156-bit keys
  - No check on the robustness/validity of keys chosen by users

Attacks against WEP (E): finding the key

➢ FMS (Fluhrer, Mantin, and Shamir) attack: weak keys

- For some WEP keys, the beginning of the cipher suite generated by RC4 is not uniformly random
- Reminder: Key K input to RC4 = 24 bits of IV + secret key (40, 104, or 232 bits)
- If weak keys are used, the beginning of the ciphertext sequence reveals a lot of information about the WEP key (faster key discovery)
  - → Recover IV (K[0], K[1], and K[2]) + first byte of the keystream.
  - → For these weak keys, the attacker can recover K[3] with a probability of 5% (instead of 1/256 in the uniform case).
  - → Once K[3] is found, find K[4], etc.
- The WEP key (128) can be calculated (probability > 50%) by listening to 4 to 6 million packets!

Attacks against WEP (E): finding the key

- **Koreck attack (improvement and extension of FMS):**
  - 16 additional correlations between the first bytes of the key and the first two bytes of the ciphertext.
  - Accelerating WEP key calculation
  - The WEP key (128) can be calculated (probability > 50%) by listening to approximately 700,000 packets!

Attacks against WEP(E): finding the key

➢ PTW attack (Physkin, Tews, and Weinmann):

- Same principle as FMS and Koreck with two major differences:
  - New correlations are exploited: Klein's correlation and Jenkins, which involves all keys and not just weak keys
  - Voting is done on the entire key, not byte by byte
- The WEP key can be calculated (probability > 50%) by listening to 35,000 to 40,000 packets!!! A few seconds on a simple computer!!!

→ FMS attacks, Koreck PTW: **linear complexity** depending on key size

The 802.11i standard

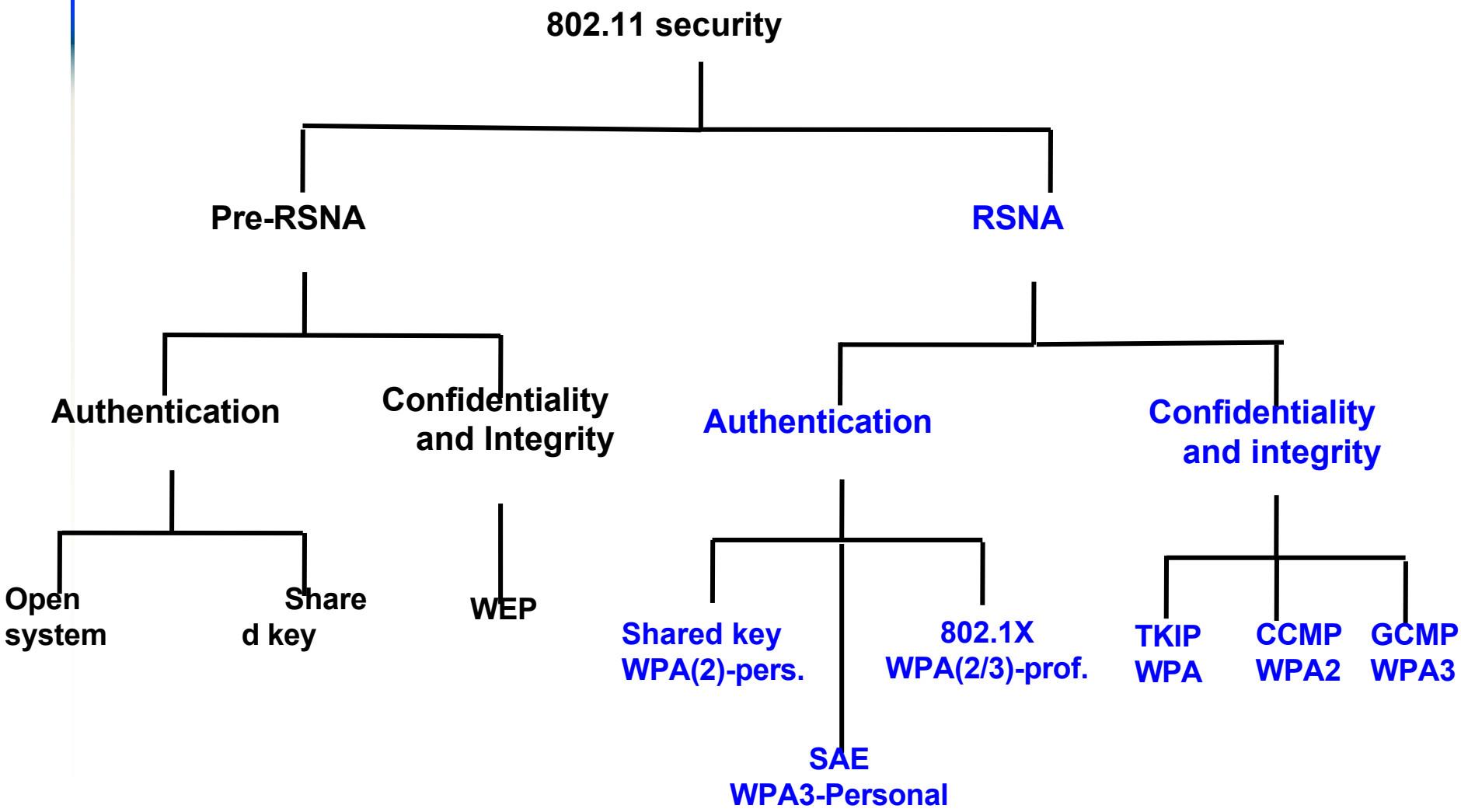
- A robust security architecture (RSN: Robust Security Network)
- Separation of user authentication and encryption/integrity
- 2003: WPA: second generation, compatible with WEP, subset of the 802.11i standard (TKIP algorithm – Temporal Key Integrity

  Protocol)
- 2004: WPA-2: third generation and paradigm shift
  (CCMP algorithm) CCMP – Counter-Mode/Cipher

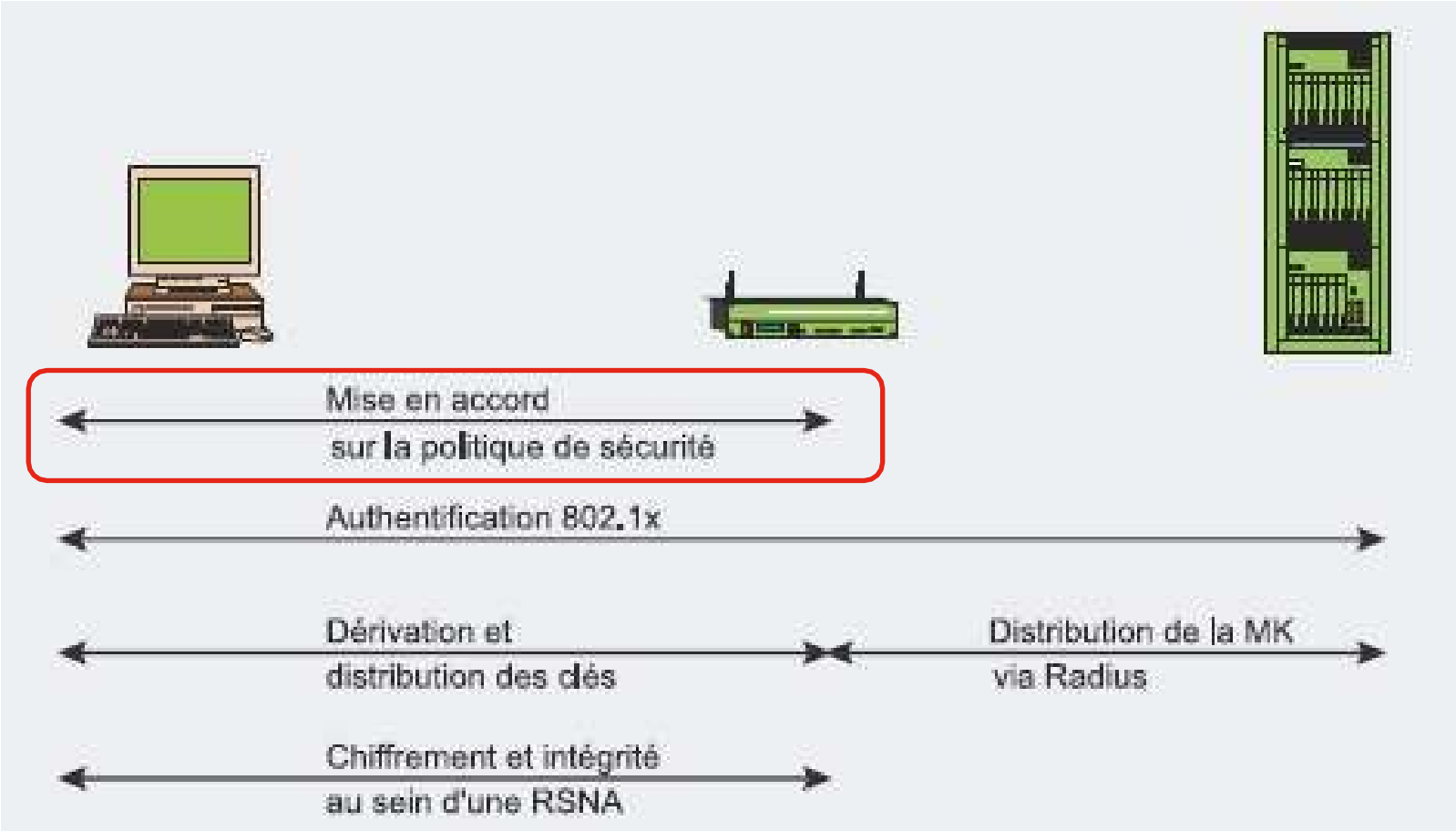
  Block Chaining Message Authentication Code

  Protocol)
- 2018/2019: WPA3: fourth generation Replacement of PSK by SAE + encryption reinforcement

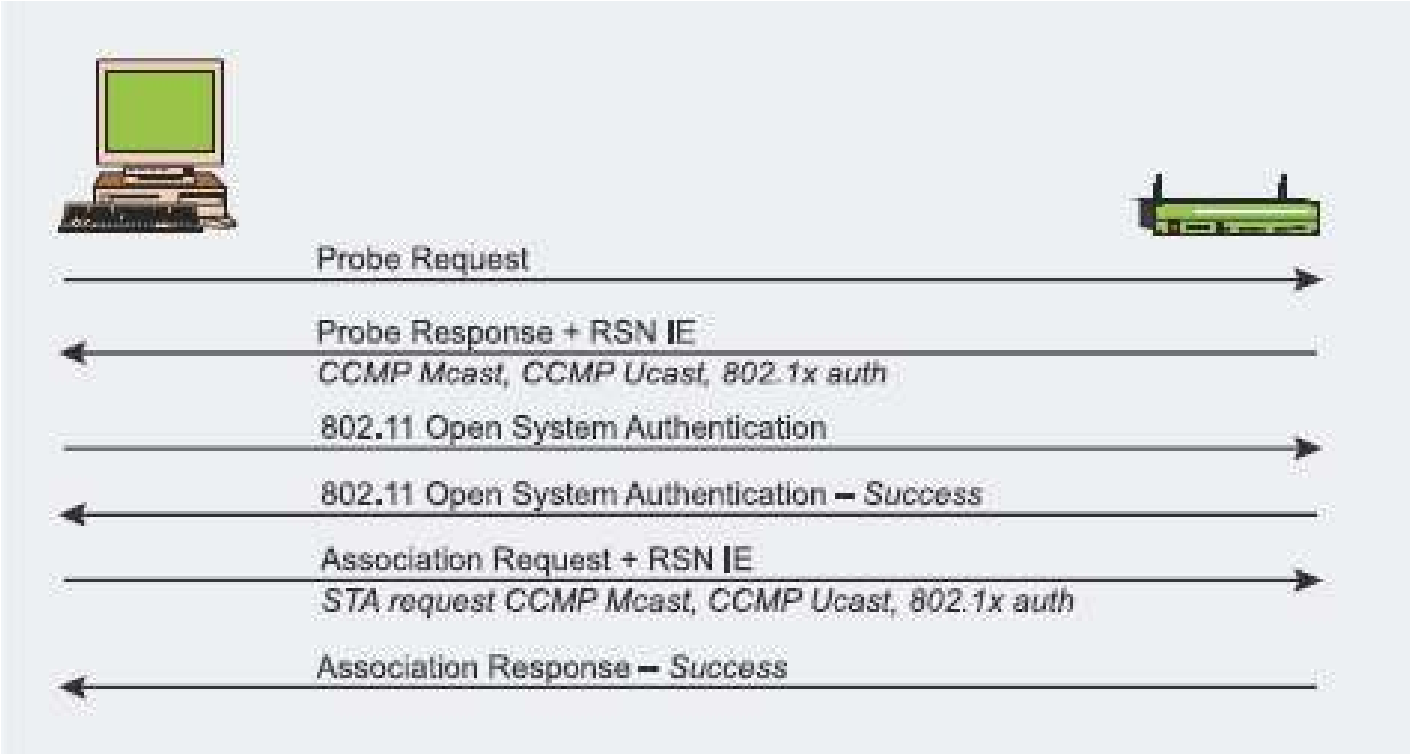
Wi-Fi security: Summary



The 802.11i standard: Operational phases



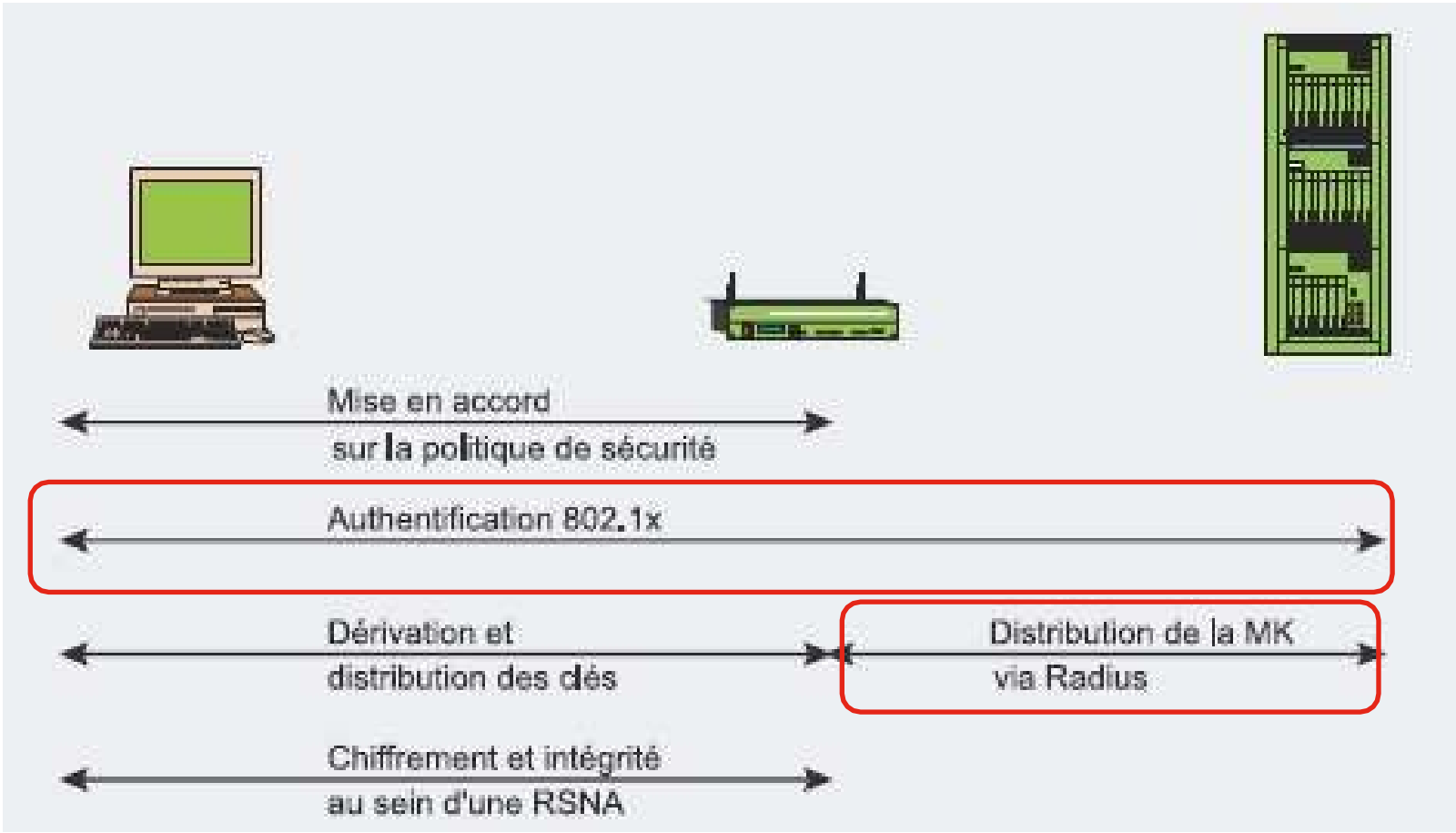
Phase 1: Agreement on social security policy



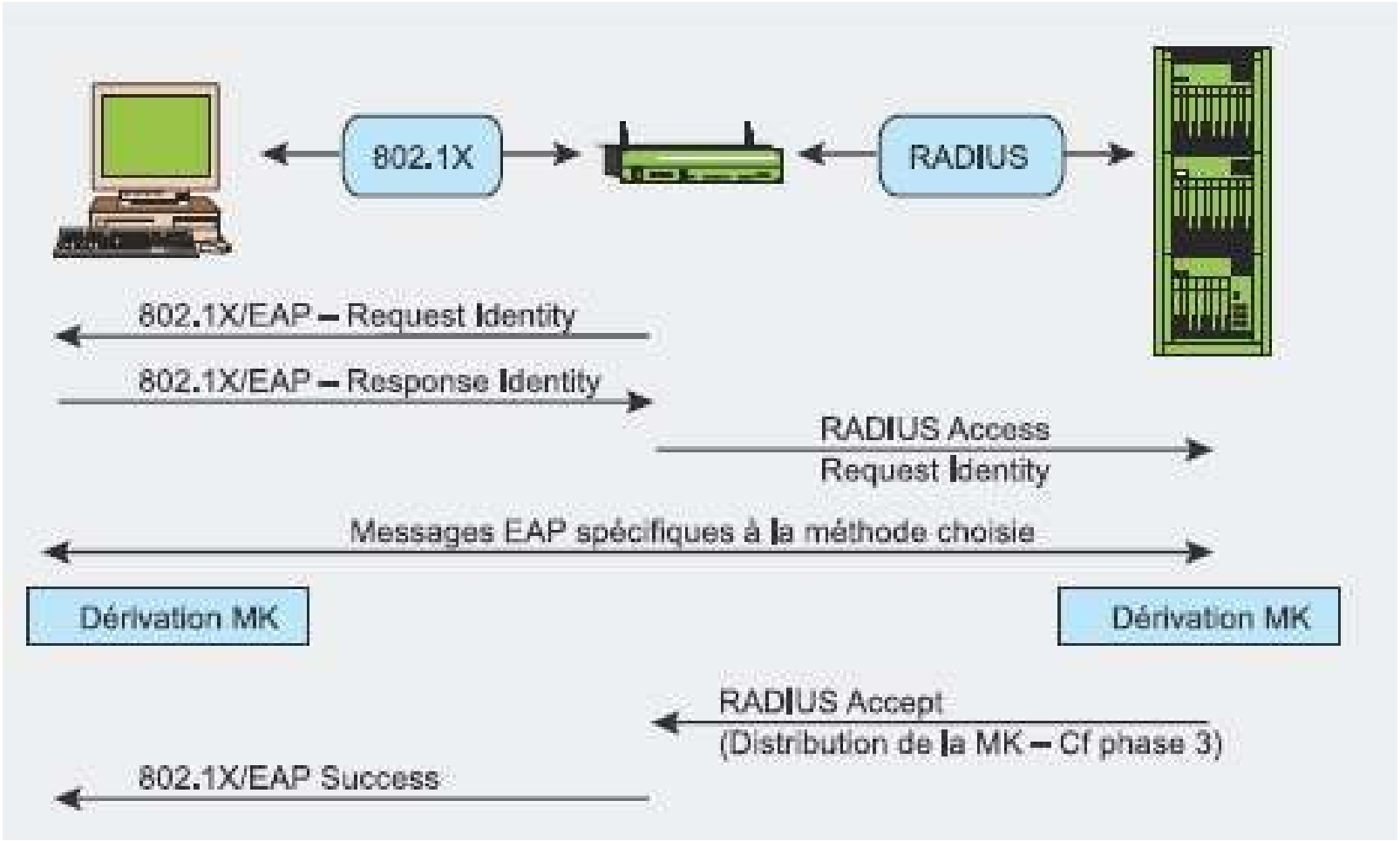
RSN IE:

- Authentication method (802.1X, PSK pre-shared key)
- Unicast encryption protocol (CCMP, TKIP, etc.)
- Multicast encryption protocol (CCMP, TKIP, etc.)

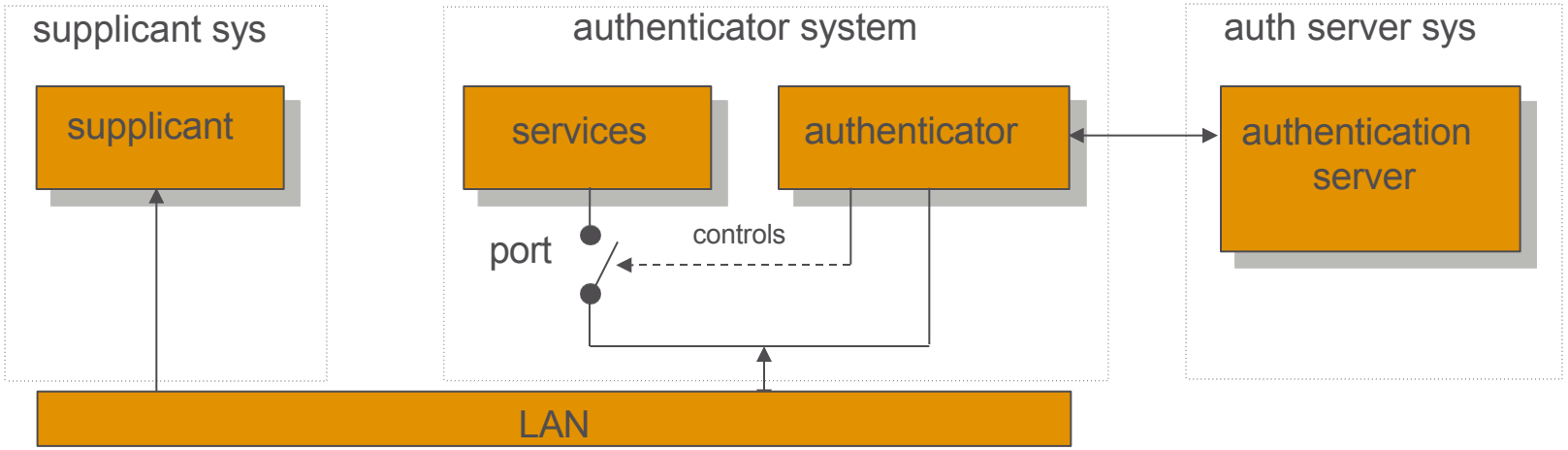
The 802.11i standard: Operational phases



Phase 2: 802.1X authentication (optional)



Phase 2: 802.1X authentication model



- The client (supplicant) requests access to a service (connect to the network)
- The controller (authenticator) controls access to the service (port status)
- The authentication server authentication (authentication server) authorizes access to the service

Phase 2: 802.1X / WiFi 802.11i correspondence

- → supplicant Mobile station (STA)
- Authenticator→ Access point (AP)
- → authentication server Server running on the access point or on a dedicated machine

- In addition, 802.11i includes:
  - Successful authentication results in the sending of a session key in addition to the positive authentication response

Phase 2: 802.1X and EAP( )

- **EAP (Extensible Authentication Protocol) [RFC 3748]**
  - Protocol designed for transporting authentication messages (e.g., MD5, PSK, TLS, TTLS, PEAP, etc.)
  - Four types of messages:
    - EAP request –supplicant→ authentication server
    - EAP response –authentication server→ supplicant
    - EAP success – successful authentication
    - EAP failure – authentication failure
  - The controller plays a passive role and does not know the content of the messages; it only recognizes EAP success and failure

Example of Radius authentication methods

Radius-MAC => Authentication by MAC addresses→ Not recommended, especially for wireless networks

EAP-MD5 => no mutual authentication between client and Radius server; the client authenticates using a password

EAP-PSK => mutual authentication between client and server using a shared secret

EAP-TLS => Mutual authentication using certificates

- TLS Handshake - Mutual authentication using certificates
- The identifier in the database is the CN of the certificate

Example of Radius authentication methods

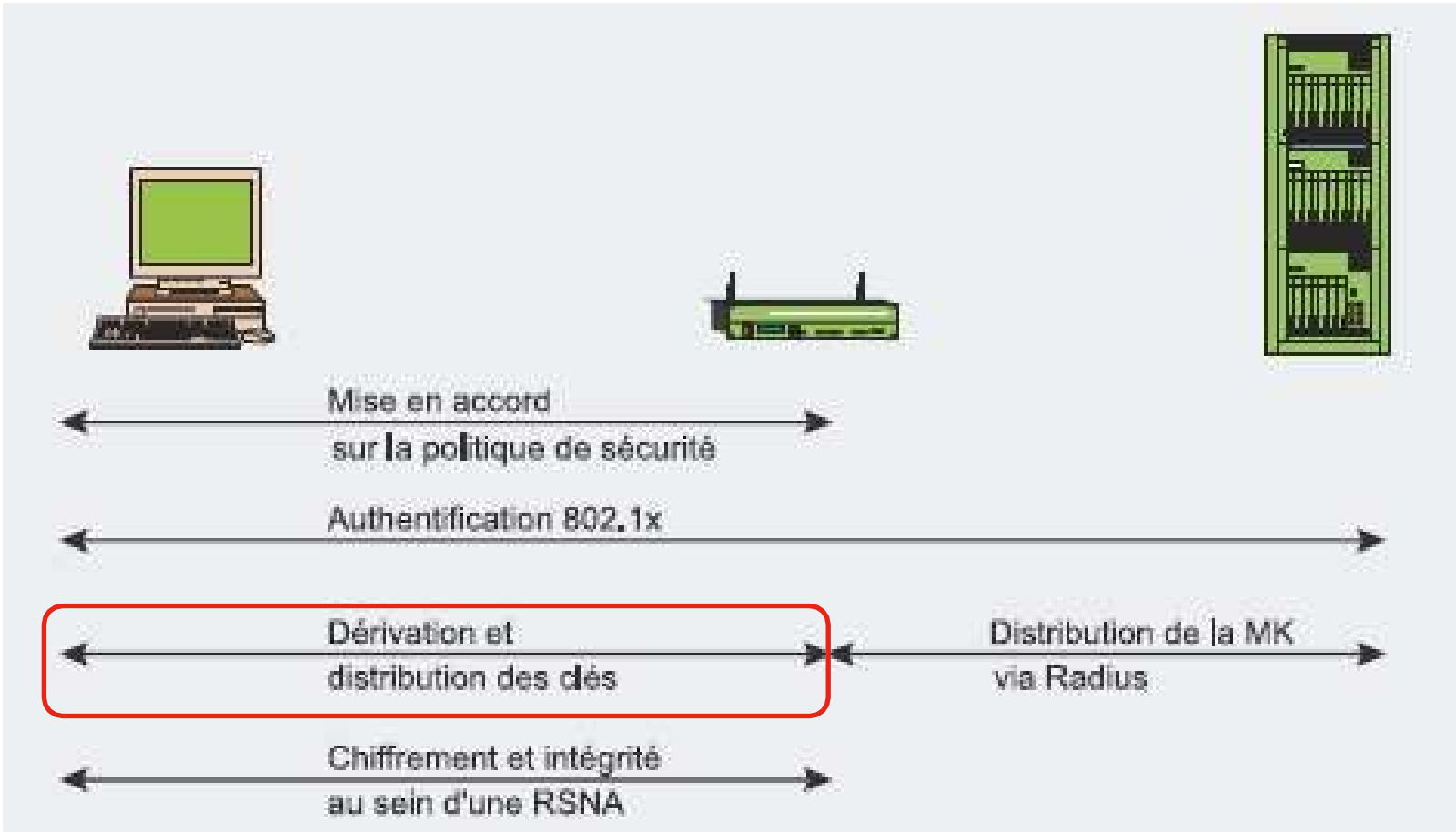
EAP-TLS => problem
need to distribute certificates to all users or machines

EAP-TTLS and PEAP => Server authentication via its certificate and client authentication via login/password

Two phases:

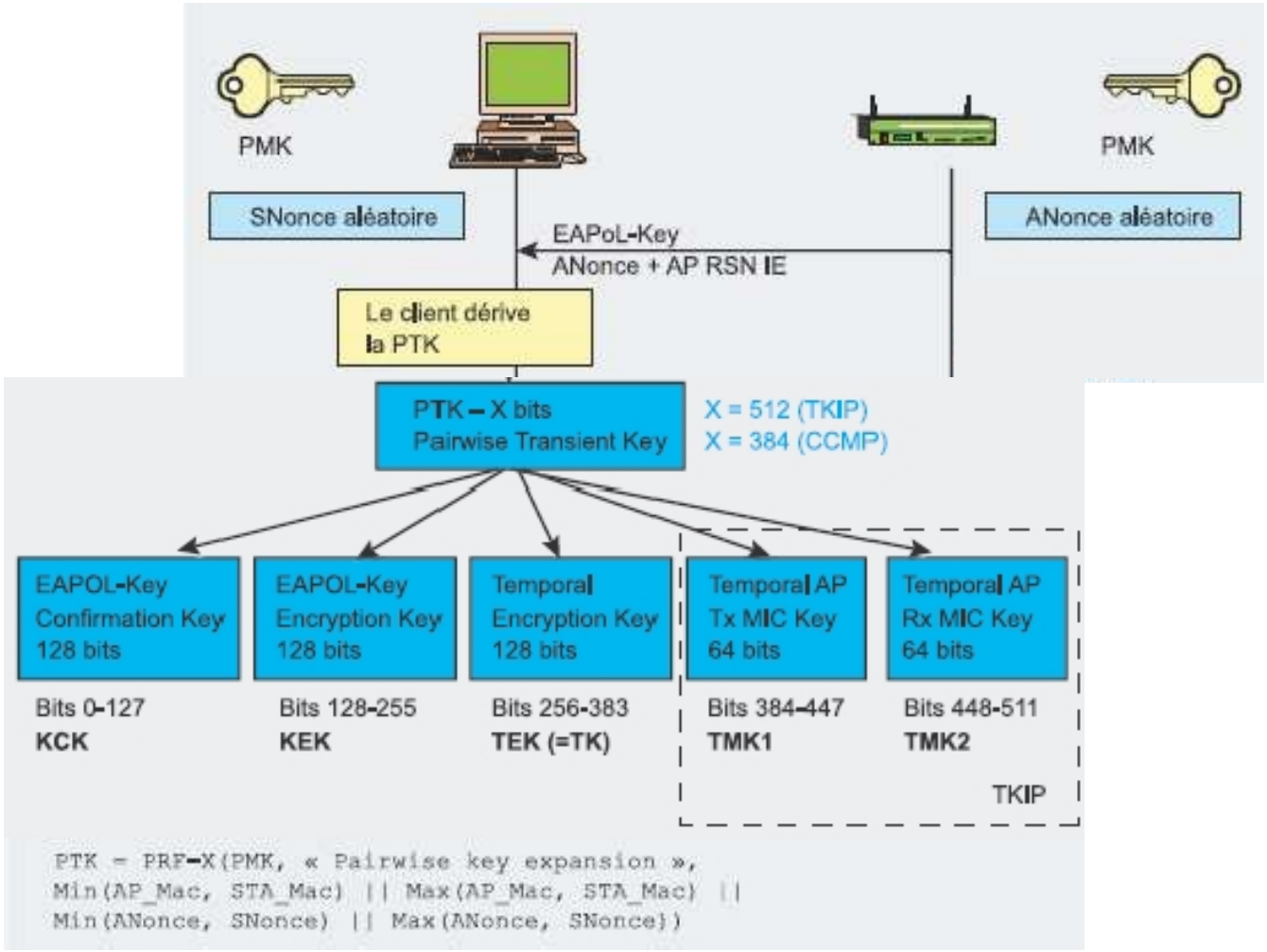
- TLS Handshake – Server authentication via certificate
- TLS Record – Creation of an encrypted tunnel. The password authentication protocol circulates in the encrypted tunnel

The 802.11i standard: Operational phases



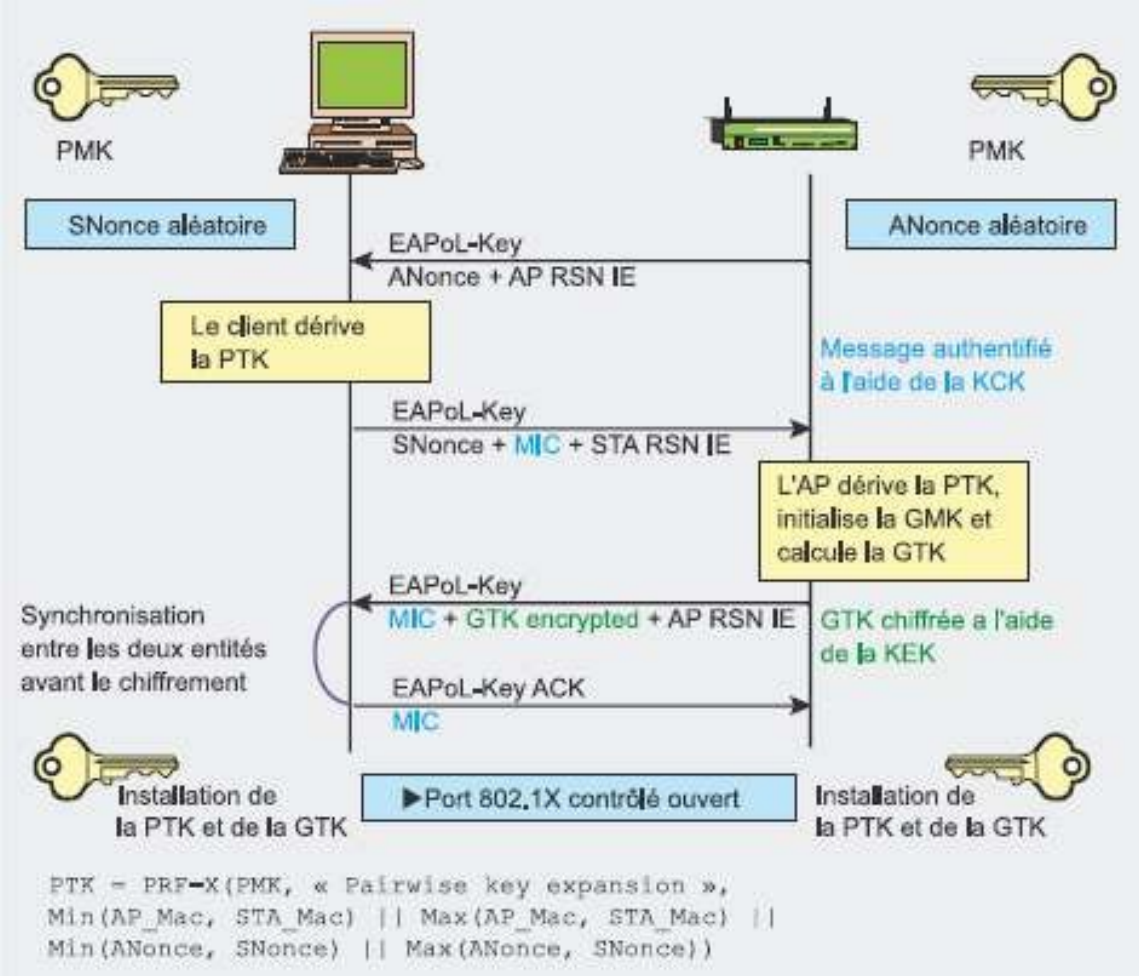
Phase 3: Key hierarchy and distribution

4-Way Handshake: pairwise key distribution



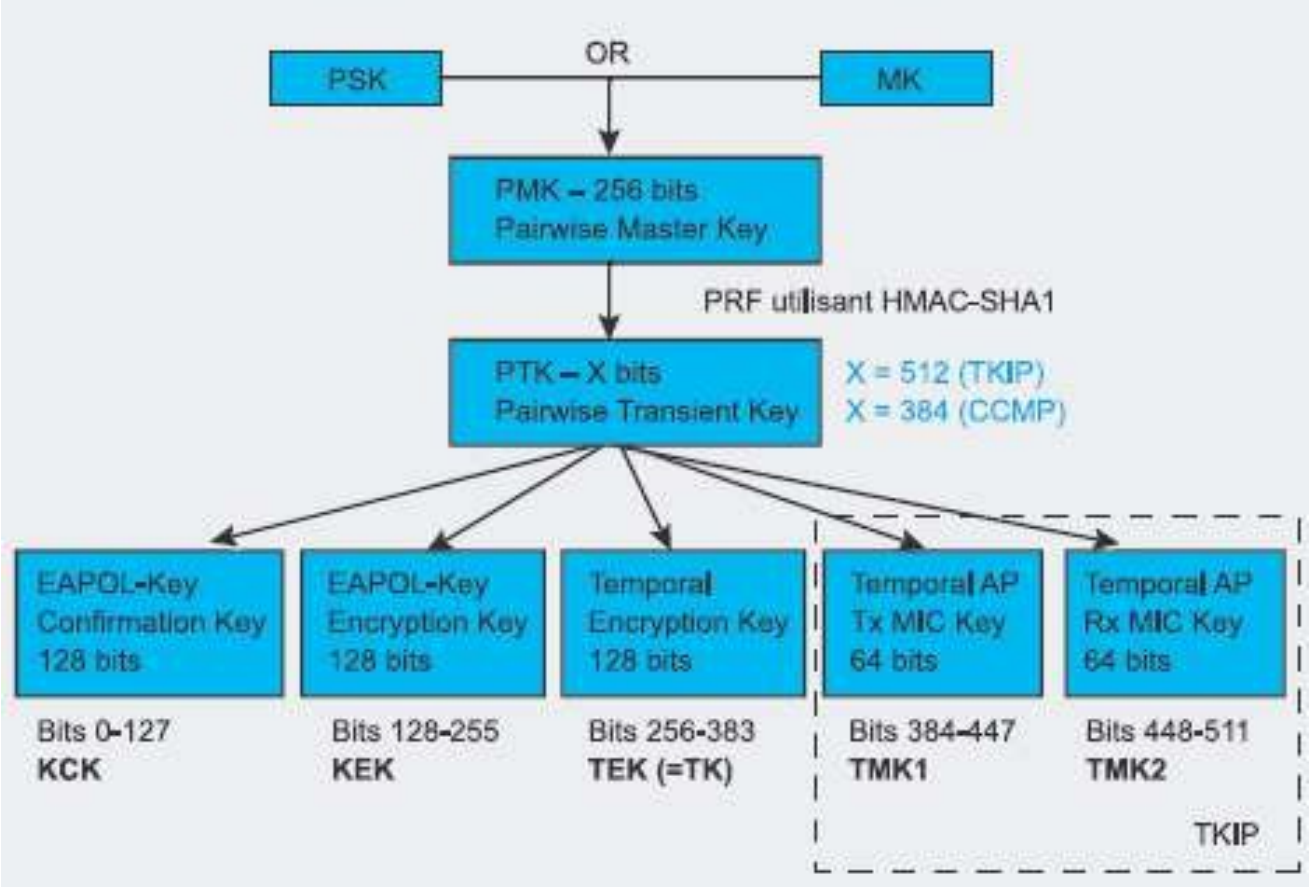
Phase 3: Key hierarchy and distribution

4-Way Handshake: pairwise key distribution



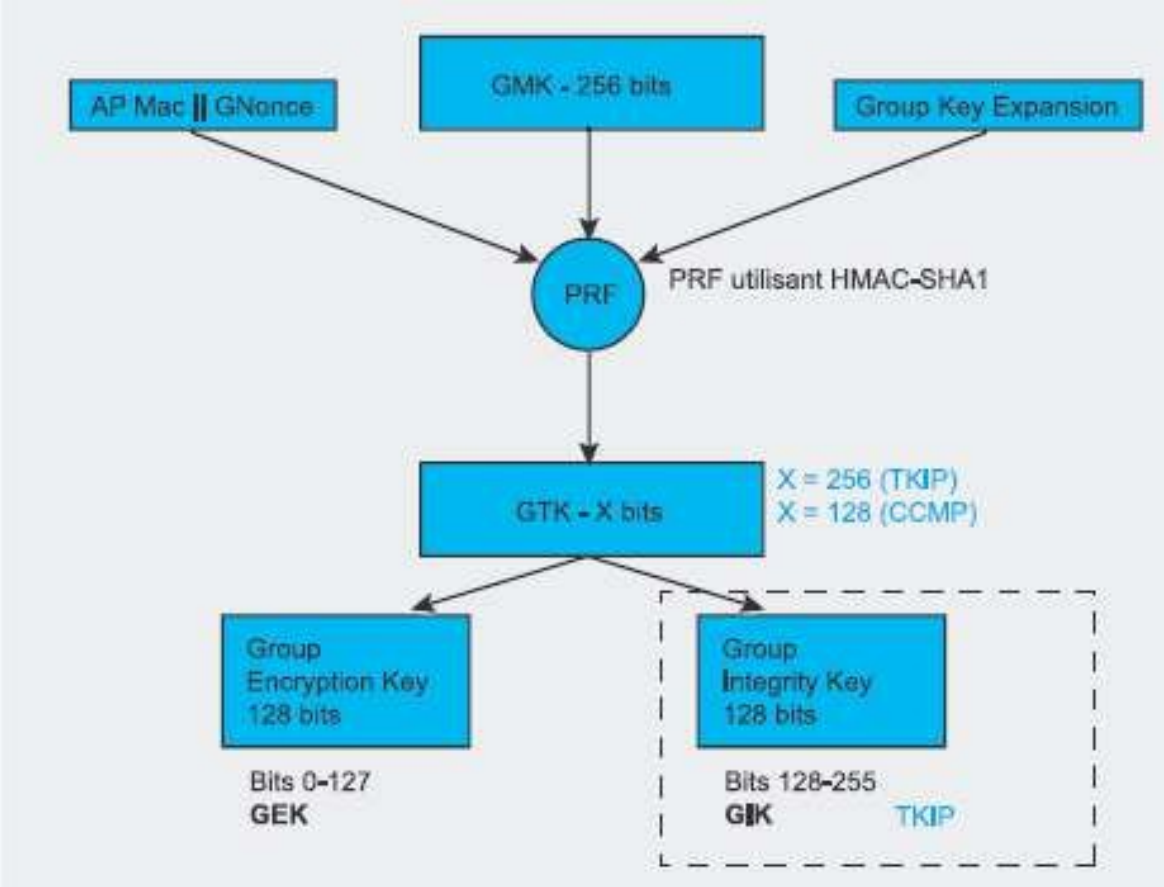
Phase 3: Key hierarchy and distribution

Pairwise key hierarchy

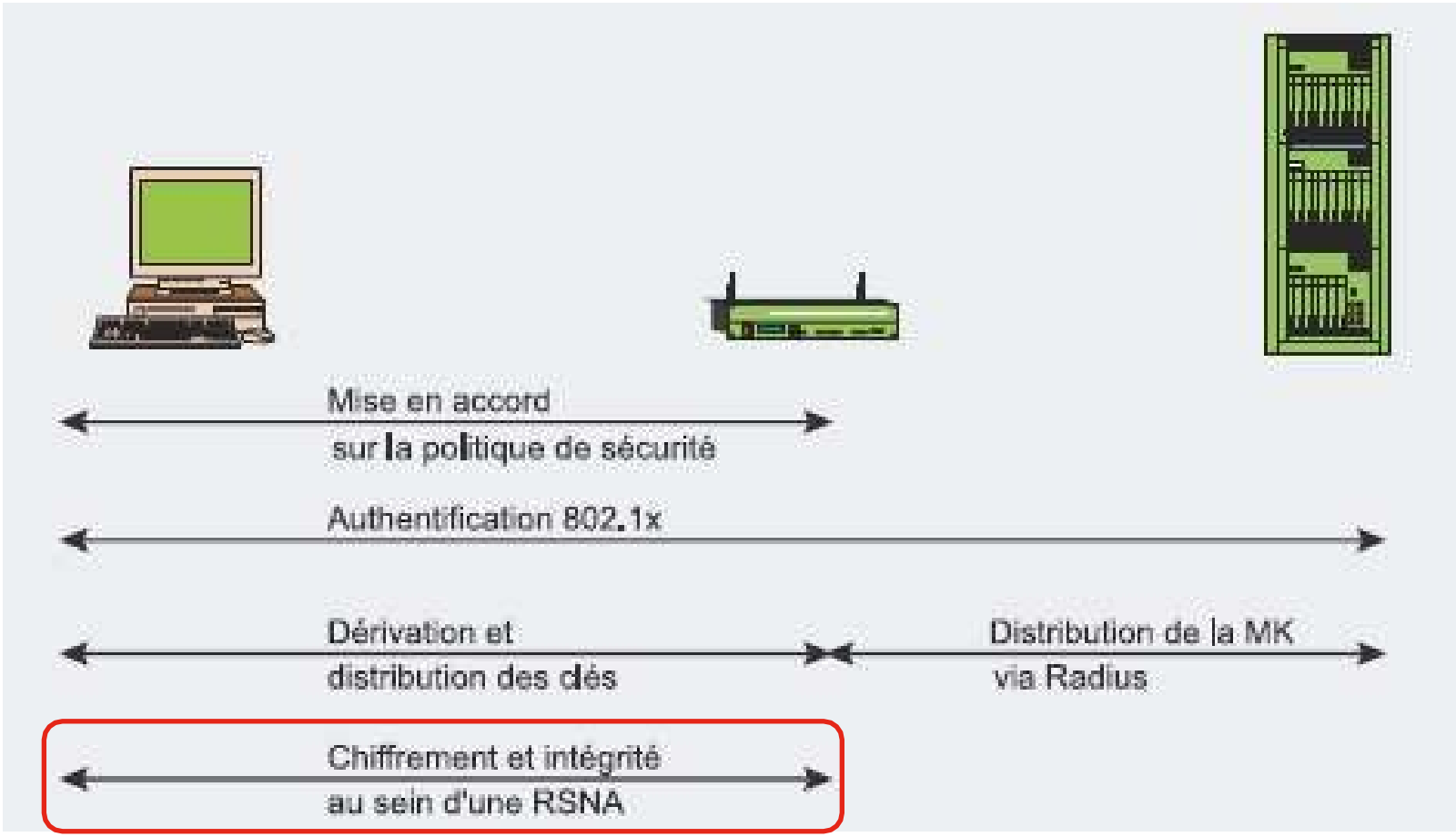


Phase 3: Hierarchy and key distribution

Group key hierarchy



The 802.11i standard: Operational phases



Phase 4: Encryption and integrity

-TKIP (Temporal Key Hash):

-IV: new method for selecting IV values, anti-replay counter, increased size (48)

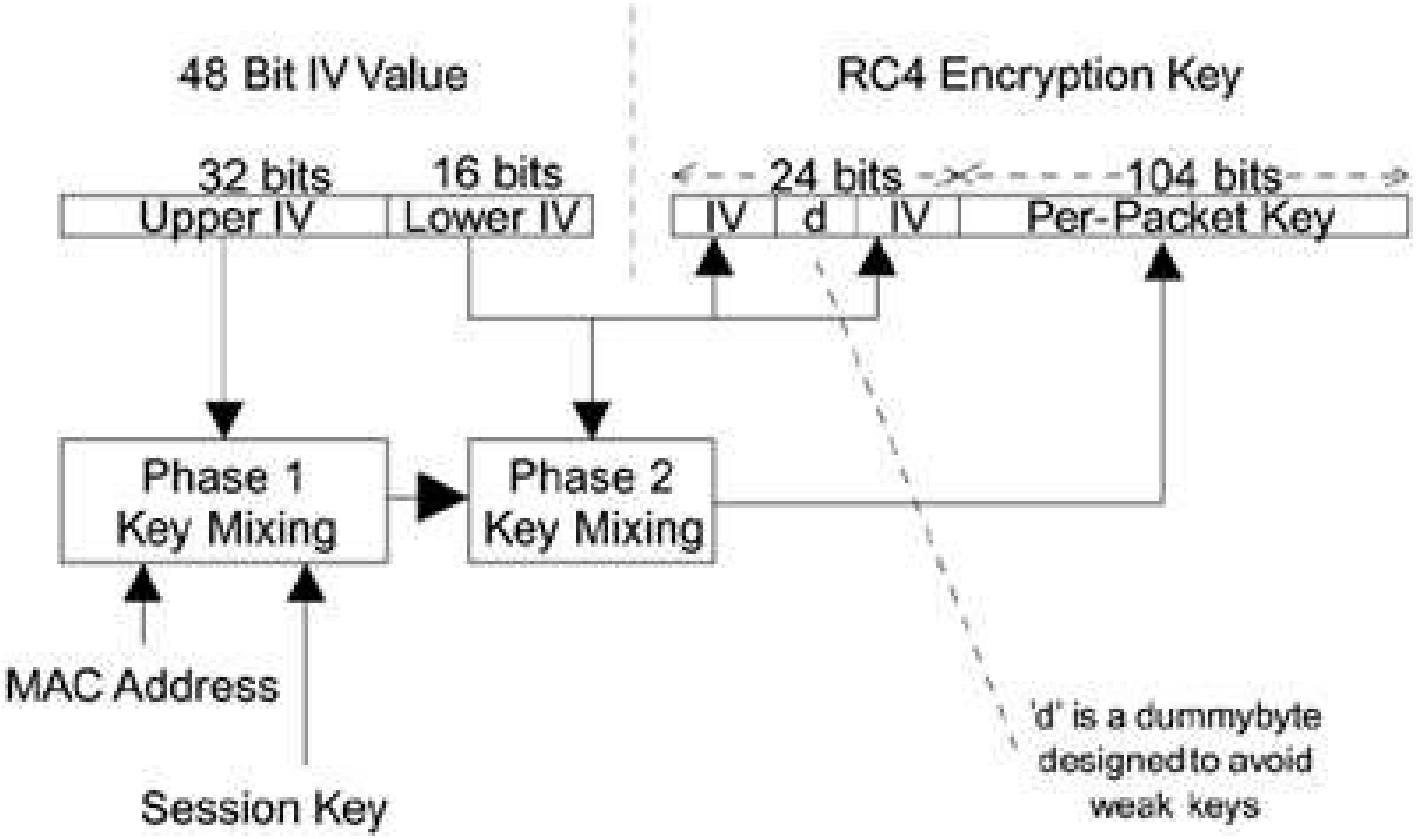
- Do not use a single key (periodic generation of temporary keys + key mixing based on IVs and temporary keys)
- Integrity: a new MIC (Message Integrity Code) based on the Michael algorithm

-CCMP (Counter-Mode/Cipher Block Chaining Message Authentication Code Protocol)

- Block cipher (AES)
- 128-bit key
- 128-bit blocks

Phase 4: Encryption and integrity TKIP (WPA)

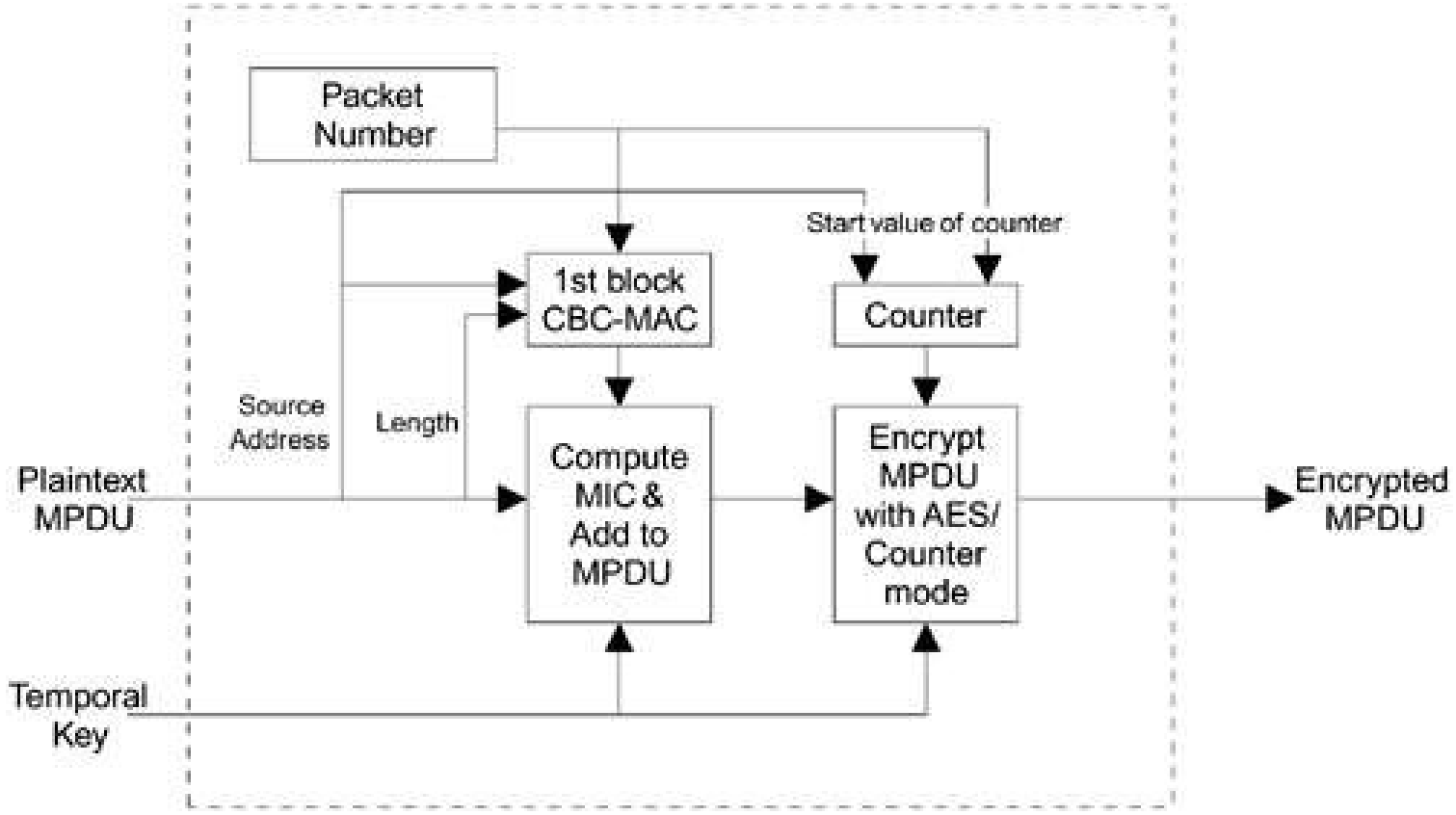
Based on RC4 (stream cipher algorithm)



http://etutorials.org/Networking/802.11+security.+wi-fi+protected+access+and+802.11i/

Phase 4: CCMP encryption and integrity (WPA2)

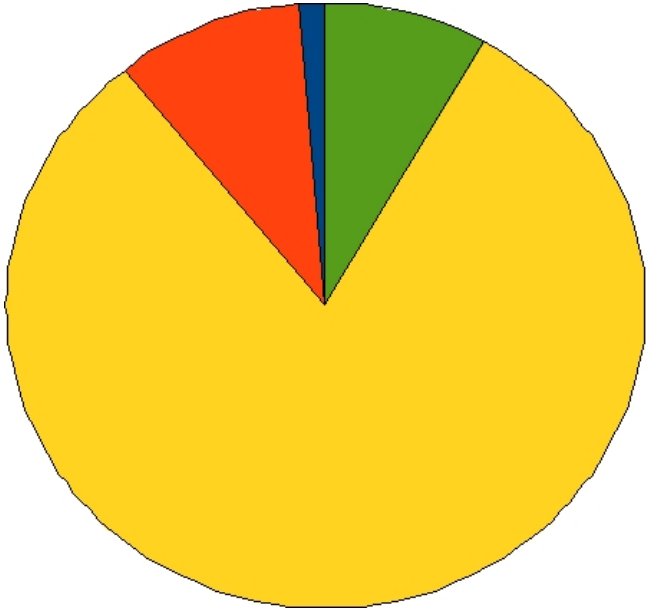
Based on AES (symmetric block cipher algorithm)



http://etutorials.org/Networking/802.11+security.+wi-fi+protected+access+and+802.11i/

Attacks against WPA/WPA2

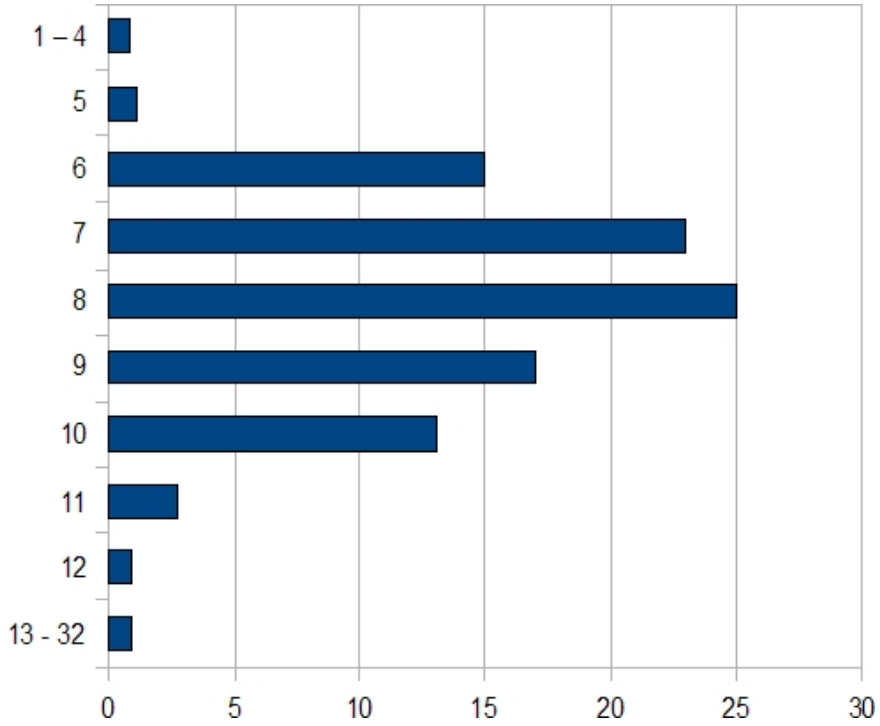
-The attack most used is most common and the most the or brute force



Number only	1.3%
Letters only	9.6
Alphanumeric	81
Non-alphanumeric	8.3

Password composition (based on 34,000 Myspace users in 2006)

Attacks against WPA/WPA2



1-4	0.82
5	1.1
6	15
7	23
8	25
9	17
10	13
11	2.7
12	0.93
13-32	0.93

Password length (based on 34,000 Myspace users in 2006)

Attacks against WPA/WPA2

❑ **Some attacks against TKIP:**

- Erik Tews and Martin Beck. 2009. Practical attacks against WEP and WPA. In WiSec.

- Mathy Vanhoef and Frank Piessens. 2014. Advanced Wi-Fi attacks using commodity hardware. In ACSAC.

-Decryption of small packets

Attacks against WPA / WPA2

❑ **Key reinstallation attacks (KRACKs): November 2017**

-Mathy Vanhoef and Frank Piessens. 2017. Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2. In ACM CCS.

- The main idea is to force the reset of anti-replay IV counters by reinstalling a key that is already in use.

❑ **Standard or implementation problem??? !!!**

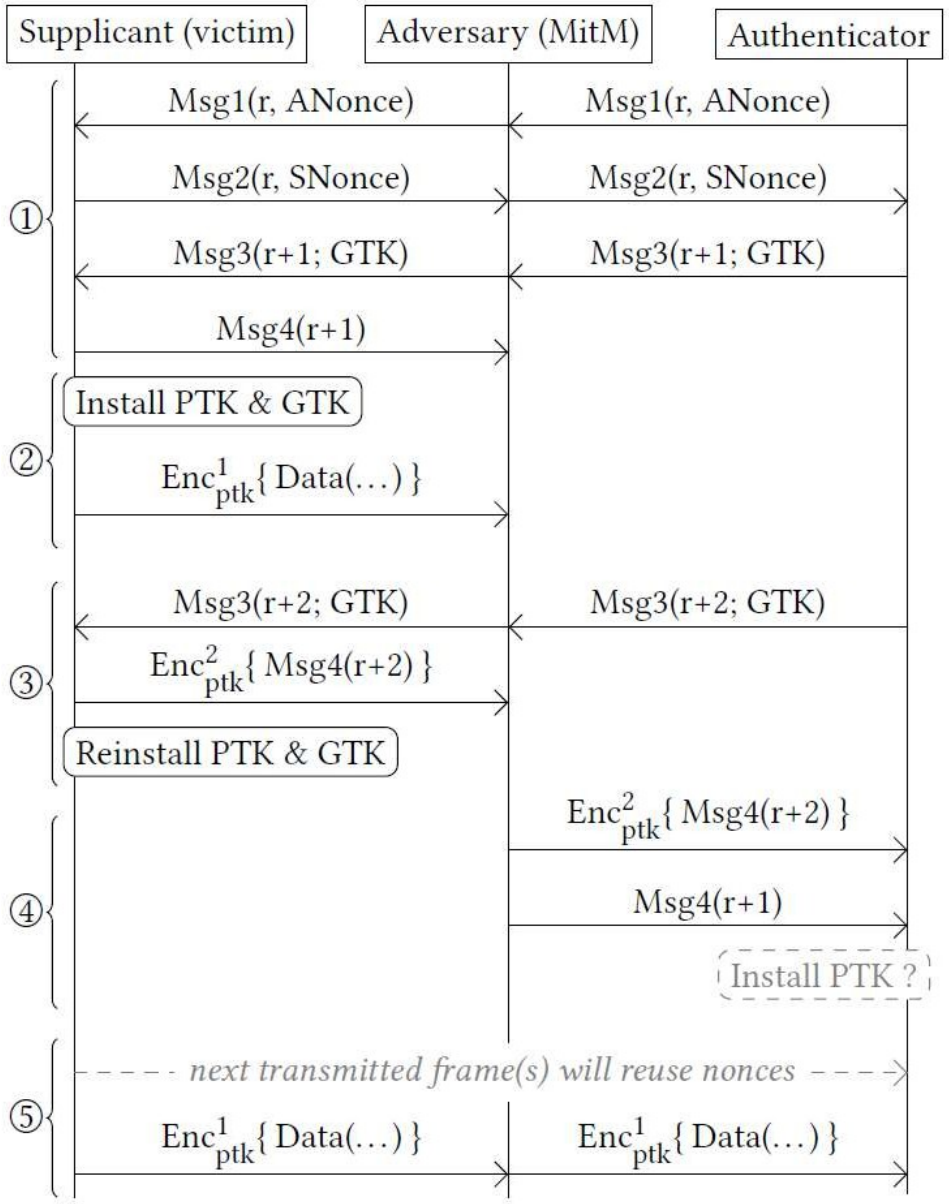
❑ **Assumptions of the attack:**

- The implementation must accept the retransmission of messages 3 in accordance with the standard (not the case for Windows and iOS implementations).

- The possibility of setting up a Man in the Middle attack with a Rogue AP having the same @ MAC (cloning the AP on another channel)

Attacks against WPA/WPA2

Principle of the attack (basic version)



Attacks against WPA/WPA2

- **Key reinstallation attacks (KRACKs): consequences**
  - TKIP: finding encryption suites and MICs→ "decryption" of all packets + injection and replay,
  - CCMP: "decryption" of some packets + replay
- **Key reinstallation attacks (KRACKs): countermeasures**
  - Do not allow message 3 to be retransmitted
  - Do not reset counters if the same key is already installed
  - Only install keys once

WPA3

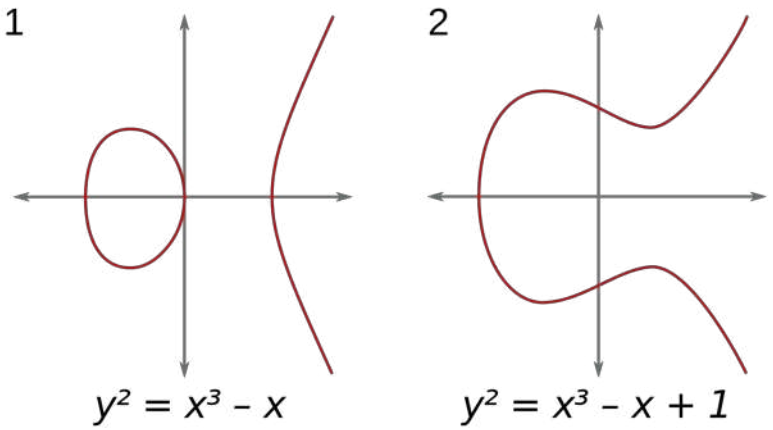
- Handshake 4 phases, replaced by exchange key "Dragonfly Key Exchange"
- Dragonfly uses cryptography based on the discrete logarithm problem for authentication and key generation (RFC 7664)
- Finite Field Cryptography (FFC), Elliptic Curve Cryptography (ECC), etc.
- In the following, we present the variant of elliptic curve cryptography (ECC)

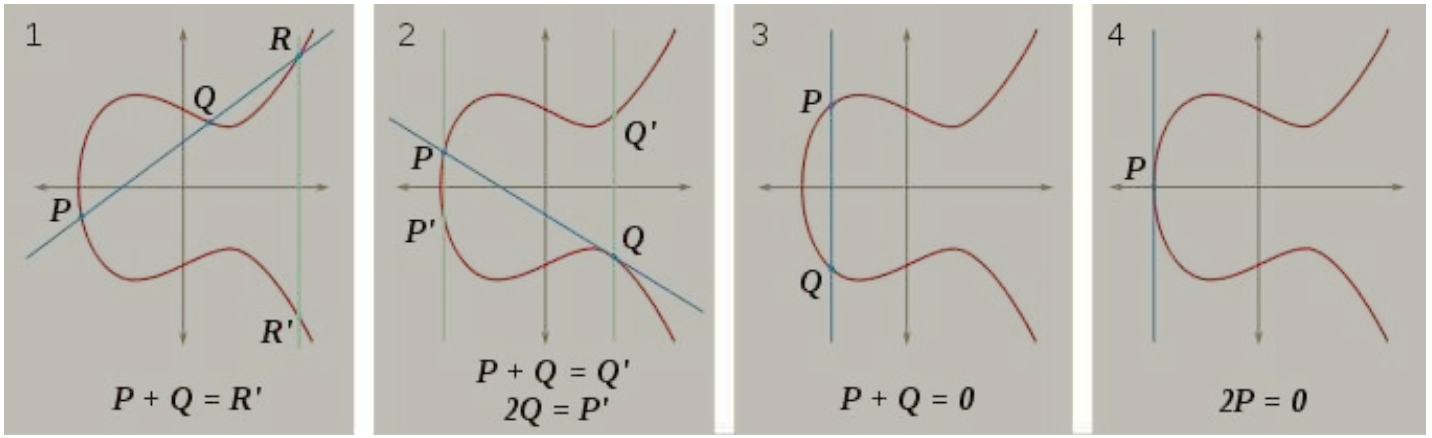
Reminder: ECC

Reminder: ECC over a finite field Z/qZ: points satisfying the equation

$$y^2 \equiv x^3 + a \cdot x + b$$

Image source: Wikipedia





Reminder: ECC

Reminder: ECC over a finite field Z/qZ: points satisfying the equation

$$y^2 \equiv x^3 + a \cdot x + b$$

	Alice	Bob
Étape 1 :	Alice et Bob choisissent ensemble une courbe elliptique $E(a, b, \mathbb{K})$ et un point P sur la courbe. Cet échange n'a pas besoin d'être sécurisé.	
Étape 2 :	Alice choisit secrètement k_A et envoie $k_A P$ à Bob. Cet échange n'a pas besoin d'être sécurisé.	Bob choisit secrètement k_B et envoie $k_B P$ à Alice. Cet échange n'a pas besoin d'être sécurisé.
Étape 3 :	Alice calcule $k_A(k_B P) = (k_A k_B)P$.	Bob calcule $k_B(k_A P) = (k_A k_B)P$.

http://www.bibmath.net/crypto/index.php?action=affiche&quoi=complements/cryptoelliptique

Reminder: ECC

Reminder: ECC over a finite field Z/qZ: points satisfying the equation

$$y^2 \equiv x^3 + a \cdot x + b$$

Very important characteristic:

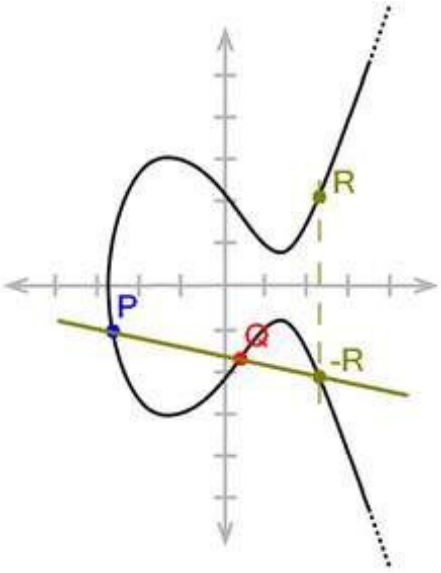
- Given a point P and a scalar k, it is "easy" to calculate Q= k.P

- Given two points P and Q, it is "impossible" "**to date**" to calculate k such that Q= k.P **within a reasonable amount of time.**

Step 1: Derivation of the Password Element (PWE)

Reminder: ECC on a finite field Z/qZ: points satisfying the equation

$$y^2 \equiv x^3 + a \cdot x + b$$



- Calculate a hash based on the participants' MAC addresses + the shared password + the counter.
- This hash is used as a "seed" for a key derivation function (KDF).
- The result is used as the x-coordinate for the curve equation. Check if it is a quadratic residue. If not

  , increase the counter by 1 and try again

Step 1: Derivation of the Password Element (RFC 7664)

```
found = 0
        counter = 1
        n = len(p) + 64 do
        {
          base = H(max(Alice,Bob) | min(Alice,Bob) | password | counter) temp =
          KDF-n(base, "Dragonfly Hunting And Pecking")
          seed = (temp mod (q - 1)) + 1
          if ( (seed^3 + a*seed + b) is a quadratic residue mod q) x =
               seed
               save = base
               found = 1
          fi
          counter = counter + 1
        } while ((found == 0) || (counter <= k))

        y = sqrt(x^3 + ax + b)
        if ( lsb(y) == lsb(save) ) PWE =
               (x,y)
        else
               PWE = (x,p-y)
        fi
```

Step 2: The Commit Exchange

q: a prime number representing the order of the generator G (the size of the cryptographic subgroup)

Each pair chooses two random numbers, private (r) and mask (m) $1 < r < q$ $1 < m < q$

scalar = (r + m) modulo q Element
= - (m * PWE)

The peers exchange their "scalar" (s) and "Element" (E), the shared secret is:

K = r * (peer-scalar * PWE + peer-Element)

kck | mk = KDF-n(F(K), "Dragonfly Key Derivation")

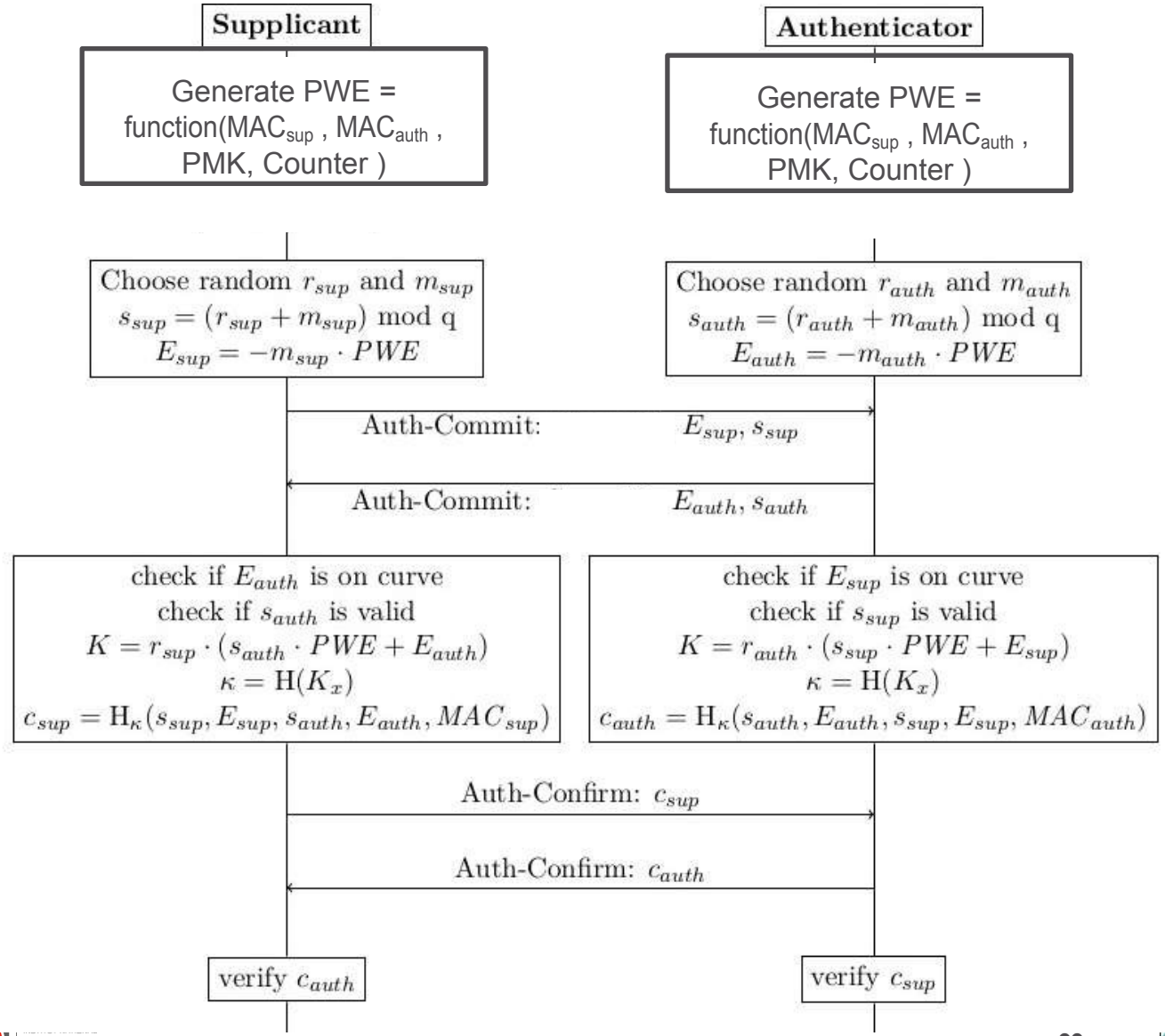
Step 3: The Confirm Exchange

Each peer calculates a confirmation hash, confirm (c), and sends it to the other peer.

confirm = H(kck | scalar | peer-scalar | Element | Peer-Element | <sender-id>)

Both parties can confirm that they have the same hash and therefore share the same secret.

WPA3 exchanges



WPA3 vs. WPA2

- In WPA2, an attacker can deauthenticate an STA, capture the handshake exchanges, and launch an **offline** dictionary attack.
- With Dragonfly, this is not feasible, because "scalar" and "element" reveal nothing "private" and "mask."
- Without these values, an attacker cannot verify whether a password is correct or not.
- The attacker must participate in an exchange with the peer to guess the password.

Privacy Respect de la vie privée

- **Unique MAC addresses:**
  - 48 bits, 24 of which identify the **manufacturer** (OUI fields)

- **SSIDs regularly broadcast by stations:**
  - **Nominative SSIDs** (organization name, event name, owner name, postal address, etc.)
  - **Geolocation capability (**WiGLe, Openbmap, etc.)
  - **Social links (**personal network sharing rate, similarity metrics, etc.**)**

- **Individual tracking:**
  - **Radio tracking** using RSSI
  - **WiFi tracking capability** (sensor or PA platform)

Respect for privacy

- **Various fields of application:**
  - Commercial centers, shopping centers, communities and transport in , mass events, targeted advertising, etc.
  - Optimization of human resource allocation, improvement of service, etc.
- **The main problem is the uniqueness of MAC addresses**
- **Anonymization of MAC addresses**
  - Is this a real solution?
- **Other approaches: hiding WiFi networks (not broadcasting the SSID)?**

Some references

- Wi-Fi Security – WEP, WPA, and WPA2 Guillaume Lehembre, 2006
- Alan Holt and Chi-Yu Huang 802.11 Wireless Networks Security and Analysis, Springer, 2010
- Aircrack-ng: https://www.aircrack-ng.org
- WiFi Professional Deployment, - The Standard 802.11, Deployment Security Aurélien Géron, Paperback, 2009
- Nikolai Tschacher, WPA3 Dragonfly Handshake– SAE Handshake, 2019
- John Franco, Elliptic Curve Public Key Cryptography, 2019

Thank you ☺